



Università Politecnica delle Marche

Facoltà di Ingegneria

Dipartimento di Ingegneria dell'Informazione

Corso di Laurea Magistrale in
Ingegneria Informatica e dell'Automazione

Sviluppo di una Zero Trust Architecture per la gestione di un impianto di energia nucleare

Docente

Prof. Luca Spalazzi

Componenti del gruppo

Fabio Tempera
Luca Marcianesi
Gabriele Vianello
Gianluca Baldelli

Anno Accademico 2025-2026

Indice

1	Introduzione	5
1.1	Il progetto	5
1.2	Obiettivi	6
1.3	Struttura dell'elaborato	6
2	Fondamenti teorici	8
2.1	Il modello Zero Trust	8
2.1.1	Principi fondamentali secondo NIST 800-207	8
2.1.2	Policy Enforcement Point e Policy Decision Point	9
2.2	Modelli formali di controllo degli accessi	9
2.2.1	Controllo degli accessi basato su ruoli	9
2.2.2	Controllo degli accessi basato su attributi	10
2.2.3	Il modello Bell-LaPadula	10
2.2.4	Algoritmo di fiducia	11
2.3	Principi di progettazione sicura	12
2.3.1	Economy of mechanism	13
2.3.2	Fail-safe defaults	13
2.3.3	Complete mediation	13
2.3.4	Separation of privilege	14
2.3.5	Least privilege	14
2.3.6	Open design	14
2.3.7	Psychological acceptability	15
2.4	Crittografia applicata e TLS	15
2.4.1	Transport Layer Security	15
2.4.2	Mutual TLS	16
2.4.3	JA3 fingerprinting	17
2.5	Componenti tecnologici	17
2.5.1	nftables	17
2.5.2	Snort	18
2.5.3	Envoy Proxy	18
2.5.4	Open Policy Agent e Rego	19
2.5.5	Splunk	19
2.5.6	MongoDB	20
2.5.7	Docker e Docker Compose	20
2.5.8	Go	20
3	Architettura del sistema	22
3.1	Struttura della repository	23
3.2	La segmentazione di rete	23

3.3	Il firewall e il punto di ingresso	24
3.4	Envoy Proxy come Policy Enforcement Point	25
3.5	Il Security Orchestrator come Policy Administrator	25
3.5.1	Alert provenienti dagli Snort	26
3.6	OPA come Policy Decision Point	26
3.7	Il Business Logic service	27
3.8	Identity Access Management service	27
3.9	I database	28
3.10	Il sistema di rilevamento delle intrusioni	28
3.10.1	Meccanismo di inoltro degli alert	29
3.11	Il flusso di autorizzazione end-to-end	29
4	Implementazione dei componenti	30
4.1	Il firewall di rete con nftables	30
4.2	Il sistema di rilevamento intrusioni con Snort	32
4.3	Envoy Proxy e la pipeline TLS	34
4.4	Il Security Orchestrator	35
4.5	Open Policy Agent e la policy in Rego	36
4.6	Il servizio Identity	37
4.6.1	Autenticazione di base	38
4.6.2	Registrazione TPM	39
4.6.3	Login TPM	41
4.6.4	Emissione JWT	43
4.7	Il servizio Business Logic	44
4.8	I database MongoDB	44
4.9	Il seeder del Business DB	45
4.10	Il forwarder Splunk e l'osservabilità centralizzata	45
5	Il modello Graphagate: Temporal Graph Network per la Zero Trust Architecture	47
5.1	Introduzione	47
5.2	Il modello base: Temporal Graph Network (v3)	47
5.2.1	Architettura del sistema	47
5.2.2	Fase di addestramento e calibrazione	49
5.2.3	Tipologie di anomalie rilevate in produzione	51
5.2.4	Valutazione sperimentale e confronto con le baseline	51
5.3	L'evoluzione: il nodo <i>Configuration</i> (schema v4)	52
5.3.1	Motivazione	52
5.3.2	Architettura del nodo <i>Configuration</i>	53
5.3.3	Risultati: il contributo del nodo config	54
5.3.4	Esperimento: granularità dell'identità del dispositivo (nodo <code>dev:guest</code>)	56
5.4	Deployment e specifiche hardware/software	58
5.4.1	Piattaforma HW/SW (addestramento e inferenza)	58
5.4.2	Serving e latenza di inferenza	58

5.4.3	Parametri di inferenza forniti dal Security Orchestrator	58
5.5	Limiti del modello	61
5.5.1	Assenza di scalabilità orizzontale	61
5.5.2	La sfida del lateral movement	61
5.5.3	Anti-poisoning gate nel live stream	61
5.6	Quadro riepilogativo: confronto di tutti i modelli	62
6	Validazione e Test del Sistema	63
6.1	Test Prestazionali e di Carico (Postman)	63
6.1.1	Ambiente di Test e Premessa Metodologica	63
6.1.2	Analisi dei Risultati e Scenari di Carico	63
6.2	Test di Sicurezza e Modello Zero Trust	66
6.2.1	Scenari di Attacco Simulati	66
6.2.2	L'Intervento dell'AI Scorer	66
7	Conclusioni e sviluppi futuri	68
7.1	Risultati ottenuti	68
7.2	Limiti e sviluppi futuri	69
	Bibliografia	71

Elenco delle figure

2.1	Tabella BellLapadula	11
3.1	Schema dell'architettura generale del sistema.	22
5.1	Schema dei layer del modello: i 3 hop di <i>GraphAttentionEmbedding</i> e le 2 teste (<i>Feature</i> e <i>Structural</i>) del <i>Dual Head Scorer</i>	50
5.2	Catena causale dello schema v4, con il nodo <i>config</i> inserito tra <i>source</i> e <i>device</i> e il <i>binding config</i> → <i>user</i> ; gli archi tratteggiati sono <i>binding</i> a messaggio-zero, il solo <i>access user</i> → <i>resource</i> porta il messaggio a 7 dimensioni.	53
6.1	Grafico Peak 30 VU	64
6.2	Grafico Peak 100 VU	65

1 Introduzione

La sicurezza informatica nei sistemi distribuiti è un campo in continua evoluzione, spinto dalla crescente complessità delle infrastrutture moderne e dall'inadeguatezza dei modelli di protezione tradizionali. Il paradigma del perimetro difensivo, in cui tutto ciò che si trova all'interno della rete aziendale è considerato affidabile per definizione, ha mostrato i propri limiti in modo sempre più evidente negli ultimi anni. Violazioni sofisticate, movimenti laterali non rilevati e compromissioni di credenziali legittime hanno reso chiaro che la fiducia implicita nella rete interna è una premessa insostenibile.

Da questa consapevolezza nasce il modello Zero Trust, la cui idea fondante può essere riassunta in un unico principio: non fidarsi mai, verificare sempre. In un'architettura Zero Trust, nessuna richiesta di accesso viene considerata sicura a priori, indipendentemente dalla provenienza, dall'identità dichiarata o dalla rete di appartenenza. Ogni accesso deve essere autorizzato esplicitamente, valutando in modo continuo il contesto dell'identità richiedente, del dispositivo utilizzato, della risorsa a cui si vuole accedere e del livello di rischio associato alla transazione.

1.1 Il progetto

Questo elaborato descrive la progettazione e l'implementazione di un'architettura Zero Trust basata su microservizi, sviluppata nell'ambito del corso di *Advanced Cybersecurity for IT*. Lo scenario scelto come dominio applicativo è quello di una centrale nucleare, un contesto volutamente estremo per quanto riguarda i requisiti di sicurezza: ruoli operativi con responsabilità nettamente distinte, informazioni classificate a vari livelli di sensibilità, accesso fisico e digitale strettamente correlati e impatti potenzialmente critici in caso di compromissione.

L'architettura è distribuita su 7 componenti principali:

1. PEP (Envoy PROXY)
2. PDP (Security Orchestrator, OPA, Modello AI, Security DB)
3. IAM
4. Logica (Business Logic, Business DB)
5. Firewall
6. IDS
7. SIEM (Splunk)

conforme ai principi definiti dalla pubblicazione NIST Special Publication 800-207, il riferimento tecnico consolidato per le implementazioni Zero Trust. Il fulcro del progetto è la

separazione netta tra il Policy Enforcement Point (PEP), responsabile dell'intercettazione del traffico e dell'applicazione delle decisioni, e il Policy Decision Point (PDP), che valuta le policy e produce il verdetto di accesso. Questa separazione garantisce che nessun componente concentri in sé sia la capacità di applicare le regole sia quella di definirle, riducendo la superficie di attacco e aumentando la chiarezza architetturale.

Il sistema implementa un controllo degli accessi adattivo e basato sul rischio, che va ben oltre la semplice validazione delle credenziali. Ogni richiesta viene analizzata tenendo conto dell'impronta TLS del client tramite JA3 fingerprinting, della presenza di un certificato client valido mediante mutual TLS, del trust score dell'identità richiedente calcolato a partire dall'analisi comportamentale e del livello di classificazione della risorsa richiesta. Il risultato è un sistema capace di prendere decisioni di accesso granulari, contestuali e dinamiche.

1.2 Obiettivi

Gli obiettivi del progetto sono articolati su più livelli. Sul piano architetturale, l'obiettivo è dimostrare come i principi Zero Trust possano essere applicati concretamente in un'infrastruttura containerizzata, con una segmentazione di rete rigorosa e una catena di autorizzazione verificabile end-to-end. Sul piano della sicurezza, si vuole mostrare come sia possibile implementare un controllo degli accessi che tenga conto simultaneamente di identità, dispositivo, rete, comportamento e classificazione della risorsa, superando i limiti dei modelli basati esclusivamente su ruoli o credenziali statiche.

Sul piano dell'osservabilità, un obiettivo esplicito è garantire la tracciabilità completa di ogni richiesta attraverso tutti i componenti del sistema, mediante la propagazione di un identificatore di correlazione univoco (**X-Request-ID**) e la centralizzazione dei log su Splunk. Tale integrazione consente sia di ricostruire il percorso di ogni transazione, sia di rilevare scenari di attacco complessi attraverso interrogazioni e allarmi configurati sulla piattaforma di monitoraggio.

Sul piano della rilevazione delle intrusioni, il progetto integra un firewall di rete basato su nftables, posizionato come primo punto di accesso all'infrastruttura, e un sistema di rilevamento delle intrusioni basato su Snort, configurato per individuare pattern di traffico anomalo come la scansione delle porte. L'insieme di questi livelli di difesa concorre a realizzare una protezione in profondità coerente con i principi Zero Trust.

1.3 Struttura dell'elaborato

L'elaborato è organizzato in modo da accompagnare il lettore dalla teoria alla pratica in modo progressivo. Il Capitolo 2 fornisce il quadro teorico completo, trattando i fondamenti della crittografia applicata, i modelli formali di controllo degli accessi, i principi di progettazione sicura e le tecnologie specifiche impiegate nel progetto. Il Capitolo 3 descrive l'architettura del sistema nei suoi componenti, flussi e scelte progettuali. Il Capitolo 4

entra nel dettaglio implementativo di ciascun modulo. Il Capitolo 5 presenta il modello di Intelligenza Artificiale di tipo Temporal Graph Network impiegato per la valutazione del rischio, descrivendone l'architettura, l'addestramento e i risultati ottenuti. Il Capitolo 6 presenta i test di carico e di sicurezza eseguiti sul sistema. Infine, il Capitolo 7 riporta le conclusioni dell'elaborato.

2 Fondamenti teorici

Prima di addentrarsi nei dettagli implementativi dell'architettura realizzata, è necessario costruire un solido quadro teorico che permetta di comprendere le scelte progettuali con piena consapevolezza del loro significato. Questo capitolo tratta i modelli formali di sicurezza, i principi di progettazione sicura, le tecnologie crittografiche alla base delle comunicazioni protette e gli strumenti specifici impiegati nel progetto.

2.1 Il modello Zero Trust

Il termine Zero Trust fu coniato da John Kindervag nel 2010, durante il suo lavoro presso Forrester Research; le radici concettuali del modello affondano tuttavia in una critica più antica al modello perimetrale. L'idea tradizionale di sicurezza informatica era quella del castello con il fossato: una rete interna considerata sicura, protetta da un perimetro difensivo verso l'esterno. Tutto ciò che si trovava all'interno del perimetro godeva di un livello implicito di fiducia. Questa assunzione si è rivelata pericolosa: una volta violato il perimetro, un attaccante poteva muoversi lateralmente attraverso la rete con scarsa resistenza.

Il modello Zero Trust rovescia questa logica in modo radicale. Nessuna entità, né utente, né dispositivo, né servizio, è considerata affidabile per default, indipendentemente dalla sua posizione nella rete. Ogni accesso deve essere esplicitamente autenticato, autorizzato e continuamente validato. La rete stessa smette di essere un elemento di fiducia e diventa semplicemente un mezzo di trasporto.

Il riferimento normativo più autorevole per l'implementazione pratica del modello è la pubblicazione NIST SP 800-207, *Zero Trust Architecture*, pubblicata nel 2020. Questo documento definisce i principi fondamentali del modello e identifica i componenti logici di un'architettura Zero Trust.

2.1.1 Principi fondamentali secondo NIST 800-207

La pubblicazione NIST SP 800-207 articola il modello Zero Trust attorno a 7 principi fondamentali:

- tutte le risorse sono considerate non affidabili, indipendentemente dalla loro posizione nella rete;
- tutte le comunicazioni devono essere protette, anche quelle interne alla rete aziendale;
- l'accesso alle risorse deve essere concesso su base per-sessione e con il minimo privilegio necessario;

- l'accesso è determinato da policy dinamiche che tengono conto dell'identità, del dispositivo, della rete e di altri attributi contestuali;
- l'integrità e la sicurezza di tutti i dispositivi connessi devono essere monitorate e verificate;
- l'autenticazione e l'autorizzazione devono essere eseguite in modo dinamico e rigoroso prima di consentire l'accesso;
- l'organizzazione deve raccogliere quante più informazioni possibile sullo stato delle risorse e delle comunicazioni, e usarle per migliorare continuamente la postura di sicurezza.

2.1.2 Policy Enforcement Point e Policy Decision Point

L'architettura Zero Trust secondo NIST si articola attorno a 2 componenti logici principali. Il Policy Enforcement Point (PEP) è il punto in cui il traffico viene intercettato e le decisioni di accesso vengono applicate. Il PEP non decide autonomamente: riceve un verdetto da un'entità separata e lo esegue, consentendo o bloccando la richiesta. Il Policy Decision Point (PDP) è invece il componente che valuta le policy e produce il verdetto. Nel modello NIST, il PDP si compone a sua volta di un Policy Engine, che applica le regole di accesso, e di un Policy Administrator, che traduce il verdetto in istruzioni operative per il PEP.

La separazione tra PEP e PDP è un requisito architetturale fondamentale, non una mera convenzione. Essa garantisce che la logica di applicazione delle regole e la logica di definizione delle regole siano mantenute distinte, riducendo la complessità di ciascun componente e limitando il raggio di impatto di una potenziale compromissione.

Nel progetto descritto in questo elaborato, il PEP è implementato da Envoy Proxy, mentre il PDP è realizzato dalla combinazione del Security Orchestrator, del modello di AI e dal motore di policy OPA.

2.2 Modelli formali di controllo degli accessi

La teoria del controllo degli accessi ha radici che risalgono agli anni Settanta e ha prodotto modelli formali che ancora oggi informano la progettazione dei sistemi di sicurezza moderni. Comprendere questi modelli è essenziale per valutare le scelte architetturali di qualsiasi sistema che gestisca risorse con livelli di sensibilità differenziati.

2.2.1 Controllo degli accessi basato su ruoli

Il Role-Based Access Control (RBAC), standardizzato nella pubblicazione ANSI/INCITS 359-2004, è un modello di controllo degli accessi in cui i permessi non sono assegnati direttamente agli utenti ma ai ruoli, e gli utenti acquisiscono i permessi in virtù dell'appartenenza a uno o più ruoli. Il riferimento NIST specifico per RBAC è invece la

pubblicazione NIST IR 7316, che definisce le specifiche funzionali del modello senza costituire essa stessa lo standard ANSI/INCITS. Questo approccio semplifica notevolmente la gestione degli accessi in sistemi con molti utenti e molte risorse.

Nel progetto il modello Role-Based Access Control costituisce il livello di base per l'astrazione e la gestione delle identità all'interno del sistema di autorizzazione. A differenza delle implementazioni RBAC tradizionali, dove il ruolo determina staticamente i permessi di accesso a specifiche risorse, in questa architettura il ruolo funge da livello di disaccoppiamento organizzativo. Le identità degli utenti vengono veicolate tramite token JWT dai quali viene estratto un attributo di business (ad esempio: `guest`, `operator`, `manager`, `admin`). Il motore di policy utilizza una mappa associativa per convertire questi ruoli organizzativi in etichette di sicurezza.

Invece di assegnare individualmente complessi set di parametri ad ogni singolo dipendente, l'appartenenza a un ruolo popola dinamicamente gli attributi strutturali necessari ai modelli successivi.

2.2.2 Controllo degli accessi basato su attributi

Il modello Attribute-Based Access Control (ABAC) estende RBAC introducendo la valutazione di attributi arbitrari relativi al soggetto, alla risorsa, all'ambiente e all'azione richiesta. Le decisioni di accesso non dipendono solo dal ruolo dell'utente, ma da una combinazione di attributi che può includere l'ora della richiesta, il tipo di dispositivo, il livello di rischio corrente e qualsiasi altra informazione contestuale rilevante.

Nell'implementazione realizzata, l'approccio ABAC permette di superare i limiti di un'autorizzazione puramente statica valutando il contesto di ogni singola richiesta in tempo reale. Agli attributi dell'oggetto (come il percorso specifico dell'endpoint e il metodo HTTP) vengono associati metadati quantitativi intrinseci di rischio.

L'elemento architetturale chiave introdotto in questa fase è la valutazione degli attributi ambientali, rappresentati specificamente da uno *score di rischio* continuo. Attraverso questo scambio di attributi, l'ABAC realizza concretamente il principio della valutazione continua del rischio.

2.2.3 Il modello Bell-LaPadula

Il modello Bell-LaPadula, proposto da David Elliott Bell e Leonard J. LaPadula nel 1973 per conto della United States Air Force, è il modello formale di riferimento per la confidenzialità delle informazioni. Il suo obiettivo è impedire che informazioni riservate fluiscano verso soggetti non autorizzati a riceverle.

Il modello introduce il concetto di livello di sicurezza, originariamente costituito da 2 dimensioni che formano una struttura a reticolo: una gerarchia totalmente ordinata e un insieme non gerarchico di compartimenti o categorie. Nel progetto realizzato, i livelli gerarchici adottati sono 5: PUBLIC, INTERNAL, CONFIDENTIAL, SECRET e TOP_SECRET, in ordine crescente di sensibilità. A questi si affiancano specifiche categorie (es.

nuclear, security). Un accesso è consentito solo se, oltre a soddisfare i vincoli di livello, il soggetto possiede un insieme di categorie che include (superset) tutte quelle richieste dall'oggetto.

Il modello formale completo si fonda su 3 proprietà fondamentali del Mandatory Access Control (MAC). La *Simple Security Property* (o proprietà *no read-up*) stabilisce che un soggetto può leggere un oggetto solo se il suo livello di autorizzazione domina quello dell'oggetto. La *Star Property* (o proprietà *no write-down*) stabilisce che un soggetto non può scrivere su un oggetto con livello di classificazione inferiore al proprio, impedendo il declassamento illecito delle informazioni. La terza proprietà, la *Discretionary Security Property* (ds-property), regola gli accessi discrezionali tramite una matrice degli accessi sovrapposta al controllo obbligatorio basato sui livelli: un soggetto può accedere a un oggetto solo se, oltre a soddisfare le 2 proprietà precedenti, la matrice degli accessi discrezionali autorizza esplicitamente quella particolare combinazione di soggetto, oggetto e modalità di accesso. Il progetto implementa le prime 2 proprietà; la ds-property non è oggetto di un'implementazione dedicata, costituendo una lacuna teorica rispetto alla formulazione completa del modello.

Esempio di sanificazione

Tuttavia, l'implementazione in OPA estende questo concetto introducendo la figura del *Trusted Subject*: viene definita una deroga controllata alla *Star Property* per consentire a un utente **admin** (TOP_SECRET) di scrivere su una specifica rotta sanitizzata di livello inferiore (SECRET), permettendo così una de-classificazione sicura delle informazioni.

A	B	C	D	E	F	G	H
Rotta Base	Metodo	Tipo Azione	Classif. Risorsa	Guest(Clr: 0 / Cat: nessuna)	Operator(Clr: 1 / Cat: hr, ops)	Manager(Clr: 2 / Cat: hr, ops, fin)	Admin(Clr: 4 / Cat: tutte)
/personnel	GET	Lettura	INTERNAL (1)	✗ No Cat	CONCESSO	CONCESSO	CONCESSO
	POST	Scrittura	INTERNAL (1)	✗ No Cat	CONCESSO	✗ BLOCCATO (+-Prop)	✗ BLOCCATO (+-Prop)
/documents	GET	Lettura	CONFIDENTIAL (2)	✗ No Cat	✗ No Cat	CONCESSO	CONCESSO
	POST	Scrittura	CONFIDENTIAL (2)	✗ No Cat	✗ No Cat	CONCESSO	✗ BLOCCATO (+-Prop)
	DELETE	Scrittura	CONFIDENTIAL (2)	✗ No Cat	✗ No Cat	CONCESSO	✗ BLOCCATO (+-Prop)
/nuclear-materia	GET	Lettura	TOP_SECRET (4)	✗ No Cat	✗ No Cat	✗ No Cat	CONCESSO
	POST	Scrittura	TOP_SECRET (4)	✗ No Cat	✗ No Cat	✗ No Cat	CONCESSO (4≤4)
	DELETE	Scrittura	TOP_SECRET (4)	✗ No Cat	✗ No Cat	✗ No Cat	CONCESSO (4≤4)
/reactor-paramet	GET	Lettura	TOP_SECRET (4)	✗ No Cat	✗ No Cat	✗ No Cat	CONCESSO
	POST	Scrittura	TOP_SECRET (4)	✗ No Cat	✗ No Cat	✗ No Cat	CONCESSO (4≤4)
/trusted-guard/...	POST	Scrittura	SECRET (3)	✗ No Cat	✗ No Cat	✗ No Cat	CONCESSO (Eccezione)

Figura 2.1: Tabella BellLapadula

2.2.4 Algoritmo di fiducia

L'algoritmo di fiducia implementato nel file `policy.rego` di OPA si distingue per la sua architettura *ibrida*, che fonde metodologie di controllo rigido degli attributi (tipiche dei sistemi Mandatory Access Control) con meccanismi di controllo basato sul punteggio.

Controllo degli Attributi: Modello Bell-LaPadula

La componente deterministica dell'algoritmo si basa su un'implementazione del modello di confidenzialità Bell-LaPadula (BLP).

Controllo basato sul punteggio: valutazione dinamica del rischio

A valle del controllo deterministico, l'algoritmo ibrido introduce una fase di computazione algoritmica basata sulla somma e sottrazione di attributi di rischio continuo. Questo garantisce che credenziali compromesse (ma formalmente valide nel modello BLP) non siano sufficienti per finalizzare un attacco.

Per ogni singola richiesta HTTP, l'algoritmo valuta:

- *beneficio dell'operazione* (B): un indice quantitativo pre-assegnato al metodo e alla rotta (es. 0.9 per rotte critiche, 0.6 per risorse interne);
- *punteggio AI di minaccia* (A): un attributo dinamico valutato in tempo reale che quantifica il livello di rischio della richiesta.

- *beneficio netto*:

$$B_{\text{netto}} = B - A \quad (2.1)$$

- *soglia di beneficio netto minimo* (B_m): il livello minimo di beneficio netto richiesto per la specifica transazione (es. 0.8 per rotte critiche, 0.3 per risorse interne);

Il blocco di autorizzazione finale si risolve tramite la disuguaglianza algebrica :

$$B - A \geq B_m \quad (2.2)$$

Questa disuguaglianza impone che un'operazione venga completata unicamente se il suo vantaggio contestuale eccede la soglia di beneficio netto minimo richiesto configurato per lo specifico endpoint. È importante chiarire la semantica di B per evitare un'interpretazione fuorviante: il parametro non misura la sensibilità o criticità della risorsa, ma il beneficio operativo, cioè quanto è necessario che l'operazione vada a buon fine per il corretto funzionamento del sistema (ad esempio, un'operazione di lettura su una rotta di monitoraggio essenziale per la sicurezza dell'impianto può avere beneficio più alto di una scrittura su una risorsa interna non urgente, indipendentemente dalla classificazione di sensibilità del dato). Il parametro che effettivamente codifica la criticità della risorsa è B_m : alle rotte più sensibili viene assegnata una soglia di beneficio netto minimo accettato molto più alta, cosicché anche un beneficio numerico elevato non comprometta la sicurezza complessiva, poiché la disuguaglianza richiede comunque che il punteggio di rischio AI resti contenuto entro un margine ristretto. I due parametri sono quindi calibrati congiuntamente per ciascuna rotta, e non in modo indipendente: un beneficio alto su una rotta critica è sempre accompagnato da una soglia di beneficio netto minimo accettato proporzionalmente più severa.

2.3 Principi di progettazione sicura

Parallelamente ai modelli formali, la letteratura di sicurezza informatica ha elaborato un insieme di principi di progettazione che guidano la costruzione di sistemi resistenti. Questi principi, enunciati originariamente da Jerome Saltzer e Michael Schroeder nel loro

articolo seminale del 1975 *The Protection of Information in Computer Systems*, rimangono di piena attualità e informano ogni scelta architetturale significativa.

2.3.1 Economy of mechanism

Il principio di economy of mechanism afferma che i meccanismi di sicurezza devono essere progettati per essere il più semplici e piccoli possibile. La semplicità riduce la probabilità di errori implementativi, semplifica la verifica della correttezza e limita la superficie di attacco. Un meccanismo complesso è più difficile da capire, da testare e da mantenere nel tempo.

Nel progetto, questo principio si manifesta nella scelta di componenti con responsabilità ben definite e limitate. nftables si occupa esclusivamente del filtraggio del traffico a livello di rete, Envoy gestisce la terminazione TLS e la delega dell'autorizzazione, OPA valuta le policy in linguaggio Rego: ciascuno di questi componenti rispetta pienamente il principio.

2.3.2 Fail-safe defaults

Il principio di fail-safe defaults stabilisce che, in assenza di una decisione di autorizzazione esplicita, il sistema deve negare l'accesso. Il comportamento predefinito deve essere il rifiuto, non il consenso. Un sistema che fallisce in modo sicuro limita i danni derivanti da errori di configurazione o da condizioni impreviste.

Questo principio è visibile in più punti dell'architettura. La policy OPA definisce `default allow = false`, garantendo che qualsiasi richiesta per cui non sia applicabile una regola esplicita di consenso venga negata automaticamente. Analogamente, la catena di nftables configura la policy di default del chain `input` a DROP, in modo che solo il traffico esplicitamente consentito possa raggiungere il sistema.

2.3.3 Complete mediation

Il principio di complete mediation afferma che ogni accesso a ogni risorsa deve essere verificato, senza eccezioni e senza possibilità di aggirare il meccanismo di controllo. Non deve esistere alcun percorso che consenta di accedere a una risorsa senza passare attraverso il punto di autorizzazione.

L'architettura del progetto garantisce la complete mediation attraverso la topologia di rete. Il Business DB, che contiene i dati più sensibili dell'applicazione, è raggiungibile esclusivamente dal servizio Business Logic attraverso la rete isolata Back-Net. Ogni richiesta al servizio applicativo deve necessariamente transitare per Envoy, che intercetta il traffico e delega l'autorizzazione prima di instradare la richiesta. Come descritto nel Capitolo 3, non esiste alcun percorso diretto dall'esterno, dal Security Orchestrator o dal motore PDP verso il Business DB: nessuno dei componenti del piano decisionale dispone di credenziali proprie su tale database, e l'unico punto di accesso resta il servizio Business Logic attraverso la rete isolata Back-Net.

2.3.4 Separation of privilege

Il principio di separation of privilege afferma che un sistema non dovrebbe concedere l'accesso o eseguire un'operazione sulla base di un'unica condizione, ma richiedere la soddisfazione di più condizioni indipendenti. La separazione dei privilegi riduce il rischio che la compromissione di un singolo fattore sia sufficiente a violare la sicurezza del sistema.

Nel progetto questo principio è applicato nel controllo degli accessi attraverso le seguenti verifiche:

1. il ruolo nel certificato e nel jwt devono coincidere
2. il certificato è obbligatorio per i ruoli admin/manager
3. Nel Open Policy Agent vengono valutati gli attributi : categoria, livello BLP e rischio associato alla richiesta

2.3.5 Least privilege

Il principio del minimo privilegio afferma che ogni entità del sistema, utente, processo o componente, deve operare con il minimo insieme di permessi necessario per svolgere le proprie funzioni. Questo limita i danni in caso di compromissione e riduce la superficie di attacco disponibile.

L'applicazione di questo principio è pervasiva nell'architettura. Il servizio Business Logic non si connette al database con un'unica utenza a privilegi globali, ma utilizza 3 credenziali MongoDB distinte e role-scoped (`operator_client`, `manager_client`, `admin_client`), ciascuna abilitata alle sole collection pertinenti al rispettivo livello. In questo modo il principio del minimo privilegio è applicato non solo dalla policy di autorizzazione, ma anche dalle credenziali con cui si raggiunge effettivamente il dato, fornendo un secondo strato di difesa indipendente. Ogni microservizio, analogamente, opera all'interno del segmento di rete strettamente necessario alle proprie funzioni.

2.3.6 Open design

Il principio di open design afferma che la sicurezza di un sistema non deve dipendere dalla segretezza del suo meccanismo di protezione, ma esclusivamente dalla segretezza delle chiavi o delle credenziali. Un sistema la cui sicurezza dipende dall'oscurità della propria implementazione risulta strutturalmente debole: qualora il meccanismo venga scoperto, l'efficacia della protezione viene del tutto compromessa.

Nel progetto, i meccanismi di protezione sono basati su standard aperti e ampiamente verificati: TLS 1.3 per la cifratura delle comunicazioni, X.509 per i certificati, SHA-256 per gli hash di integrità. La sicurezza risiede nella segretezza delle chiavi private, non nella segretezza degli algoritmi. Le policy OPA sono espresse in Rego, un linguaggio leggibile e auditabile, la cui correttezza può essere verificata in modo indipendente; il documento non include tuttavia il codice Rego della policy né nel corpo del testo né in appendice, il

che rende di fatto impossibile per il lettore verificare l'affermazione di auditabilità sulla base del materiale presentato.

2.3.7 Psychological acceptability

Il principio di psychological acceptability afferma che i meccanismi di sicurezza devono essere progettati in modo da non creare ostacoli eccessivi agli utenti legittimi. Se i controlli di sicurezza sono troppo onerosi, gli utenti troveranno modi per aggirarli. La sicurezza deve essere praticabile, non solo teoricamente corretta.

In un'architettura Zero Trust, questo principio si traduce nella trasparenza dei controlli: l'autenticazione e l'autorizzazione avvengono in modo il più possibile automatico, senza richiedere azioni aggiuntive all'utente se non nei casi in cui il rischio lo giustifichi. Nell'implementazione realizzata, tuttavia, l'autenticazione a più fattori è richiesta a ogni singolo login, indipendentemente dal livello di rischio della sessione: dopo la verifica di username e password, il sistema emette sempre un codice OTP monouso inviato via email che l'utente deve confermare prima che venga rilasciato il token di sessione. Questa scelta è in tensione diretta con il principio appena enunciato, che prevede l'introduzione di attriti aggiuntivi solo quando il rischio lo giustifica e non in modo incondizionato; va inoltre osservato che l'OTP via email è generalmente considerato in letteratura un secondo fattore relativamente debole, una caratteristica rilevante per un sistema che protegge un impianto nucleare.

2.4 Crittografia applicata e TLS

Le comunicazioni sicure all'interno dell'architettura si fondano su protocolli crittografici standard. La comprensione dei meccanismi sottostanti è necessaria per valutare le garanzie di sicurezza offerte dal sistema.

2.4.1 Transport Layer Security

Il protocollo TLS (Transport Layer Security) è lo standard de facto per la protezione delle comunicazioni su reti non affidabili. La versione corrente, TLS 1.3, definita nella RFC 8446, introduce significativi miglioramenti rispetto alle versioni precedenti: eliminazione di suite crittografiche deboli, riduzione della latenza dell'handshake da 2 round-trip a uno, e forward secrecy obbligatoria attraverso l'uso esclusivo di scambi di chiave effimeri basati su Diffie-Hellman.

Il processo di handshake TLS stabilisce un canale sicuro tra client e server attraverso una sequenza di messaggi che negozia le suite crittografiche, autentica le parti e deriva le chiavi di sessione. Il risultato è un canale che garantisce confidenzialità (attraverso la cifratura simmetrica), integrità (attraverso MAC o AEAD) e autenticazione (attraverso certificati digitali). È opportuno precisare che la forward secrecy obbligatoria di TLS 1.3 riguarda esclusivamente le chiavi di sessione, derivate in modo effimero a ogni handshake: i certificati client statici impiegati nel mutual TLS non beneficiano direttamente di

questa proprietà, poiché la chiave privata associata al certificato resta fissa nel tempo. La compromissione di tale chiave privata, pur non esponendo le sessioni passate già concluse, comprometterebbe comunque l'autenticazione futura del client fino alla revoca o al rinnovo del certificato.

Nel progetto, Envoy termina le connessioni TLS in ingresso, gestendo il processo di handshake e l'estrazione dei metadati crittografici attraverso il TLS Inspector. L'uso di TLS 1.3 è rilevante anche per il JA3 fingerprinting: client che negoziano con cipher suite o versioni TLS datate producono hash JA3 distinti e riconoscibili, consentendo al sistema di identificare connessioni anomale anche in presenza di credenziali valide.

2.4.2 Mutual TLS

Il mutual TLS (mTLS) è un'estensione del protocollo TLS in cui entrambe le parti, client e server, si autenticano reciprocamente mediante certificati digitali X.509. Nel TLS standard, solo il server presenta un certificato per autenticarsi al client; nell'mTLS, anche il client è tenuto a presentare un certificato valido, firmato da una Certificate Authority (CA) fidata dal server.

Questo meccanismo è particolarmente adatto agli ambienti Zero Trust, perché fornisce un'autenticazione forte basata su crittografia a chiave pubblica, indipendente da credenziali riutilizzabili come username e password. Un client che non disponga di un certificato valido firmato dalla CA interna non può stabilire una connessione, indipendentemente da qualsiasi altra credenziale. Va segnalato che il progetto non prevede alcun meccanismo di revoca dei certificati, né tramite Certificate Revocation List (CRL) né tramite Online Certificate Status Protocol (OCSP): in un'architettura Zero Trust la capacità di revocare rapidamente un certificato compromesso costituisce un requisito fondamentale, che in questo caso resta privo di copertura. Una mitigazione parziale, non implementata nella versione corrente del progetto ma proponibile come lavoro futuro, consisterebbe nell'adozione di certificati a vita molto breve (short-lived certificates, tipicamente con validità di ore) rilasciati da una CA interna automatizzata: questo approccio, diffuso in architetture Zero Trust moderne, riduce drasticamente la finestra di esposizione di un certificato compromesso senza richiedere l'infrastruttura aggiuntiva di un servizio CRL o OCSP, spostando di fatto il problema della revoca verso quello, più gestibile, del rinnovo automatico frequente.

Nel progetto, Envoy è configurato con `require_client_certificate: false`, rendendo facoltativa la presentazione di un certificato client firmato dalla CA interna. I certificati sono generati tramite OpenSSL con il parametro di estensione `extendedKeyUsage=clientAuth`, garantendo che possano essere utilizzati esclusivamente per l'autenticazione del client. Al termine dell'handshake, quando un certificato è presente, Envoy ne inietta i metadati nell'header `X-Forwarded-Client-Cert`; il Security Orchestrator li interpreta per risolvere l'identità del soggetto richiedente in modo crittograficamente verificato e li inoltra al livello di policy. Questa configurazione è in tensione con la filosofia Zero Trust dichiarata per il progetto: rendere facoltativo il certificato a livello TLS significa demandare per intero la verifica al Security Orchestrator e, più a valle, al servizio Identity

(si veda la discussione al Capitolo 3 e alla Sezione ??), introducendo un punto di fiducia implicita su Envoy. Sebbene il controllo applicativo successivo blocchi correttamente le richieste prive di certificato per i ruoli che lo richiedono, l'assenza di enforcement a livello di trasporto resta una scelta architetturale che meriterebbe un'analisi critica più esplicita nel documento, dato che espone comunque superficie applicativa a un client non ancora autenticato a livello TLS.

2.4.3 JA3 fingerprinting

Il JA3 fingerprinting è una tecnica di identificazione del client basata sui parametri dell'handshake TLS. Sviluppata da John Althouse, Jeff Atkinson e Josh Atkins presso Salesforce nel 2017, costruisce una firma identificativa del client a partire da 5 campi dell'handshake: la versione TLS proposta, le cipher suite supportate, le estensioni TLS incluse, i gruppi di curve ellittiche e i formati di punto ellittico.

Questi 5 campi vengono concatenati in una stringa con separatori definiti e poi sottoposti a hashing MD5, producendo un identificatore di 32 caratteri esadecimali che è caratteristico della combinazione di libreria TLS e configurazione utilizzata dal client. Client diversi, anche se usano le stesse credenziali, produrranno hash JA3 differenti se il loro stack TLS è diverso. Questo rende il JA3 uno strumento utile per rilevare impersonificazioni, bot e client anomali anche quando le credenziali presentate sono valide. La tecnica presenta tuttavia limiti ben noti che il progetto non affronta esplicitamente: un tasso di collisione non trascurabile tra client diversi che condividono la stessa libreria e versione TLS, la possibilità di spoofing intenzionale dell'impronta da parte di un attaccante che ne conosca i parametri di calcolo, e una progressiva perdita di efficacia con l'adozione di TLS 1.3, dove la riduzione della variabilità osservabile dell'handshake limita la distintività delle impronte, fino all'inutilizzabilità completa quando il client adotta l'estensione Encrypted Client Hello (ECH), che cifra interamente i parametri dell'handshake altrimenti usati per il calcolo del fingerprint.

Nel progetto, Envoy è configurato con `enable_ja3_fingerprinting: true` nel filtro TLS Inspector. Envoy calcolarne il digest MD5 del JA3 ed espone la stringa JA3 come variabile di metadato e la inietta negli header della richiesta inoltrata al Security Orchestrator.

2.5 Componenti tecnologici

2.5.1 nftables

nftables è il framework di filtraggio dei pacchetti del kernel Linux, introdotto come successore di iptables a partire dal kernel 3.13. A differenza di iptables, nftables offre una sintassi unificata per IPv4 e IPv6, supporto nativo per set e mappe di indirizzi, e un'architettura interna più efficiente basata su una macchina virtuale integrata nel kernel.

Nel progetto, nftables opera come firewall di rete posizionato tra il client esterno e il resto dell'infrastruttura. La sua configurazione definisce una tabella `inet filter` le cui 2 catene principali, `input` e `output`, adottano tutte una policy di default DROP, così che solo il traffico esplicitamente consentito venga accettato in ciascuna direzione. In particolare la catena `output` ammette il solo traffico in uscita strettamente necessario, ossia la risoluzione DNS e la comunicazione verso i microservizi interni. La catena `input` accetta il traffico locale, il traffico appartenente a connessioni già stabilite e il traffico TCP verso la porta di Envoy da indirizzi non presenti nella lista di blocco, loggando ogni pacchetto accettato o rifiutato tramite il gruppo NFLOG 100.

2.5.2 Snort

Snort è un sistema di rilevamento e prevenzione delle intrusioni di rete (NIDS/NIPS) open source, originariamente sviluppato da Marty Roesch nel 1998 e successivamente acquisito da Cisco. Opera analizzando il traffico di rete in tempo reale, confrontando i pacchetti catturati con un insieme di regole configurabili per rilevare pattern corrispondenti ad attività malevole note.

Snort può operare in 3 modalità: sniffer (stampa i pacchetti sulla console), packet logger (salva i pacchetti su disco) e network intrusion detection system (analizza i pacchetti e genera alert). Nel progetto, Snort è configurato in modalità NIDS con output su console, condivide lo stack di rete del container firewall tramite la direttiva `network_mode: service:firewall`.

La regola custom configurata utilizza il preprocessore `sfportscan` per rilevare scansioni di porte, abilitato con il parametro `sense_level: low` per minimizzare i falsi positivi. Una regola Snort aggiuntiva segnala esplicitamente la rilevazione di un port scan TCP quando vengono rilevati più di 5 pacchetti SYN dalla stessa sorgente nell'arco di 5 secondi. Questo scenario è uno dei vettori di attacco testati esplicitamente nel progetto, con client di test che simulano la scansione rapida di un intervallo di porte.

2.5.3 Envoy Proxy

Envoy è un proxy L4/L7 open source sviluppato originariamente da Lyft e successivamente donato alla Cloud Native Computing Foundation (CNCF). È progettato per essere il piano dati di architetture a microservizi, gestendo la comunicazione tra servizi con funzionalità avanzate di load balancing, circuit breaking, osservabilità e sicurezza.

Nel contesto del progetto, Envoy svolge il ruolo di Policy Enforcement Point. La sua configurazione YAML definisce un listener sulla porta 8443 che, grazie al filtro `tls_inspector`, ispeziona i parametri dell'handshake TLS prima ancora che la connessione sia completamente stabilita. Il filtro `http_connection_manager` gestisce la connessione HTTP una volta che l'handshake TLS è concluso. Envoy è configurato per richiedere il certificato client e per loggare in formato JSON strutturato una serie di informazioni sulla connessione, tra cui la versione TLS, la cipher suite, l'indirizzo remoto e l'hash JA3, propagando l'header `X-Request-ID` per garantire la tracciabilità.

Il protocollo `ext_authz` di Envoy permette di delegare la decisione di autorizzazione a un servizio esterno, in questo caso il Security Orchestrator, prima di instradare la richiesta verso il backend. Questo è il meccanismo attraverso cui si realizza la separazione tra PEP e PDP.

2.5.4 Open Policy Agent e Rego

Open Policy Agent (OPA) è un motore di policy general-purpose open source, mantenuto dalla CNCF, che permette di esprimere e valutare policy in modo unificato attraverso diversi domini applicativi. OPA riceve in input un documento JSON che rappresenta il contesto della richiesta e valuta le policy scritte in Rego, restituendo un documento JSON che rappresenta la decisione.

Rego è un linguaggio dichiarativo derivato da Datalog, progettato specificamente per la definizione di policy. A differenza di un linguaggio imperativo, in Rego si descrive *cosa* deve essere vero perché una policy sia soddisfatta, non *come* verificarlo. Questo rende le policy leggibili, componibili e verificabili in modo indipendente rispetto al codice applicativo che le esegue.

Nel progetto, OPA opera come Policy Decision Point puro. Riceve dall'Orchestratore un payload che contiene ruolo dell'utente, risorsa richiesta, metodo e score del rischio generato dal modello di AI. OPA valuta tutte queste condizioni, come descritto in precedenza nella sezione 2.2, restituendo un verdetto binario allow/deny. La separazione tra la policy e il codice che la applica garantisce che le regole possano essere modificate, testate e verificate in modo indipendente dalla logica applicativa.

2.5.5 Splunk

Splunk è una piattaforma di analisi operativa dei dati macchina, ampiamente utilizzata come SIEM (Security Information and Event Management) in ambito enterprise. Raccolge log da sorgenti eterogenee, li normalizza, li indicizza e li rende ricercabili e correlabili attraverso il linguaggio di query SPL (Search Processing Language).

Nel progetto, Splunk opera come centro di osservabilità dell'intera architettura. Ogni microservizio invia i propri log a Splunk tramite l'HTTP Event Collector (HEC), un endpoint HTTP che accetta eventi in formato JSON autenticati tramite token. L'uso del formato JSON strutturato permette a Splunk di indicizzare automaticamente i campi dei log, rendendoli immediatamente disponibili per ricerche e correlazioni.

Il campo `X-Request-ID`, propagato da Envoy e ripreso da ogni microservizio lungo la catena di elaborazione, è il meccanismo fondamentale per la correlazione degli eventi. Dato un identificatore di richiesta, è possibile ricostruire in Splunk il percorso completo della transazione attraverso tutti i componenti: il log del firewall nftables, il log di accesso di Envoy con l'hash JA3 e il codice di risposta, il log del Security Orchestrator con l'esito della valutazione OPA e le eventuali ragioni di deny, e il log del servizio di Business Logic.

2.5.6 MongoDB

MongoDB è un database orientato ai documenti, appartenente alla famiglia NoSQL, che archivia i dati in formato BSON (Binary JSON). La sua flessibilità dello schema e il supporto nativo per documenti annidati lo rendono particolarmente adatto a modellare strutture dati eterogenee e ricche di contesto come quelle richieste da un'architettura Zero Trust.

Nel progetto sono presenti 2 istanze MongoDB con ruoli distinti. Il Security DB conserva i dati di identità e dispositivo gestiti dall'iam-service e dal Security Orchestrator: le credenziali degli utenti con ruolo, livello di clearance e flag di enrollment TPM (collection `identity_users`), le credenziali WebAuthnFIDO2 dei dispositivi registrati (`device_fingerprints`), lo stato effimero delle sessioni OTP (`otp_sessions`), la blocklist dei token JWT revocati (`jwt_blocklist`), lo storico immutabile degli eventi di autenticazione (`auth_events`) e i contatori per il rate limiting (`rate_limits`). Il Business DB archivia i dati applicativi della centrale nucleare, organizzati in 7 collection: `personnel`, `access-badges`, `zones`, `reactor-parameters`, `maintenance-orders`, `documents` e `nuclear-materials`.

2.5.7 Docker e Docker Compose

Docker è una piattaforma di containerizzazione che permette di eseguire applicazioni in ambienti isolati e riproducibili. Ogni container condivide il kernel del sistema operativo host ma dispone di un proprio filesystem, spazio di rete e namespace di processi, garantendo un isolamento sufficiente per la segmentazione dei microservizi.

Docker Compose è lo strumento di orchestrazione usato per definire e gestire l'insieme dei container che compongono l'applicazione. Il file `docker-compose.yaml` del progetto definisce 17 servizi: oltre ai componenti principali dell'architettura (`firewall`, `envoy`, `security-orchestrator`, `opa` e `business-logic`), comprende le 3 istanze di rilevamento delle intrusioni (`snort`, `snort-internal` e `snort-mid`), il servizio di identità `iam-service` con il relativo server di posta di sviluppo `mailhog`, il microservizio di scoring `ai-inference`, i 2 database `business-db` e `security-db`, l'utility `seeder`, lo stack di osservabilità (`splunk` con l'universal forwarder `splunk-uf`) e il generatore di alert di test `alerts-tester`. La topologia di rete è definita attraverso 4 reti Docker isolate: `Front-Net`, che collega i client al firewall e al Security Orchestrator; `Auth-Net`, che connette il Security Orchestrator a OPA, al servizio di identità e alla Security DB; `Back-Net`, che connette esclusivamente Business Logic e Business DB; e `Snort-Net`, dedicata al trasporto degli alert dalle istanze Snort verso il Security Orchestrator. Questa segmentazione garantisce che nessun componente possa comunicare direttamente con un servizio al di fuori del proprio segmento di rete autorizzato, applicando la complete mediation a livello infrastrutturale.

2.5.8 Go

Go, o Golang, è un linguaggio di programmazione compilato e tipizzato staticamente, sviluppato da Google e rilasciato nel 2009. Le sue caratteristiche principali includono la

semplicità del modello di concorrenza basato su goroutine e canali, la produzione di binari staticamente linkati senza dipendenze runtime, e una libreria standard ricca che include primitive per la gestione di connessioni TCP, HTTP e TLS.

I servizi applicativi del progetto, Security Orchestrator e Business Logic, sono scritti in Go. Le linee guida di sviluppo interne al progetto prescrivono la propagazione del contesto tramite `context.Context` in tutte le chiamate che coinvolgono I/O, il wrapping degli errori con `fmt.Errorf` per preservare la traccia completa, e l'inclusione del `X-Request-ID` in tutti i log per garantire la tracciabilità. I client di test, scritti sia in Go sia in Python, simulano scenari di accesso legittimo, accesso anomalo con cipher suite deprecated e scansione delle porte, fornendo la base per la validazione dell'architettura.

3 Architettura del sistema

L'architettura di ZTALeaks si fonda su un principio fondamentale: nessun elemento interno riceve fiducia implicita e ogni componente opera con responsabilità rigorosamente delimitate. Il sistema implementa concretamente la separazione tra Policy Enforcement Point (PEP) e Policy Decision Point (PDP) prescritta dalle linee guida dello standard NIST SP 800-207. Questa separazione viene realizzata tramite un ecosistema di microservizi isolati a livello di rete e containerizzati, i quali cooperano attraverso scambi protetti e log tracciabili in modo centralizzato.

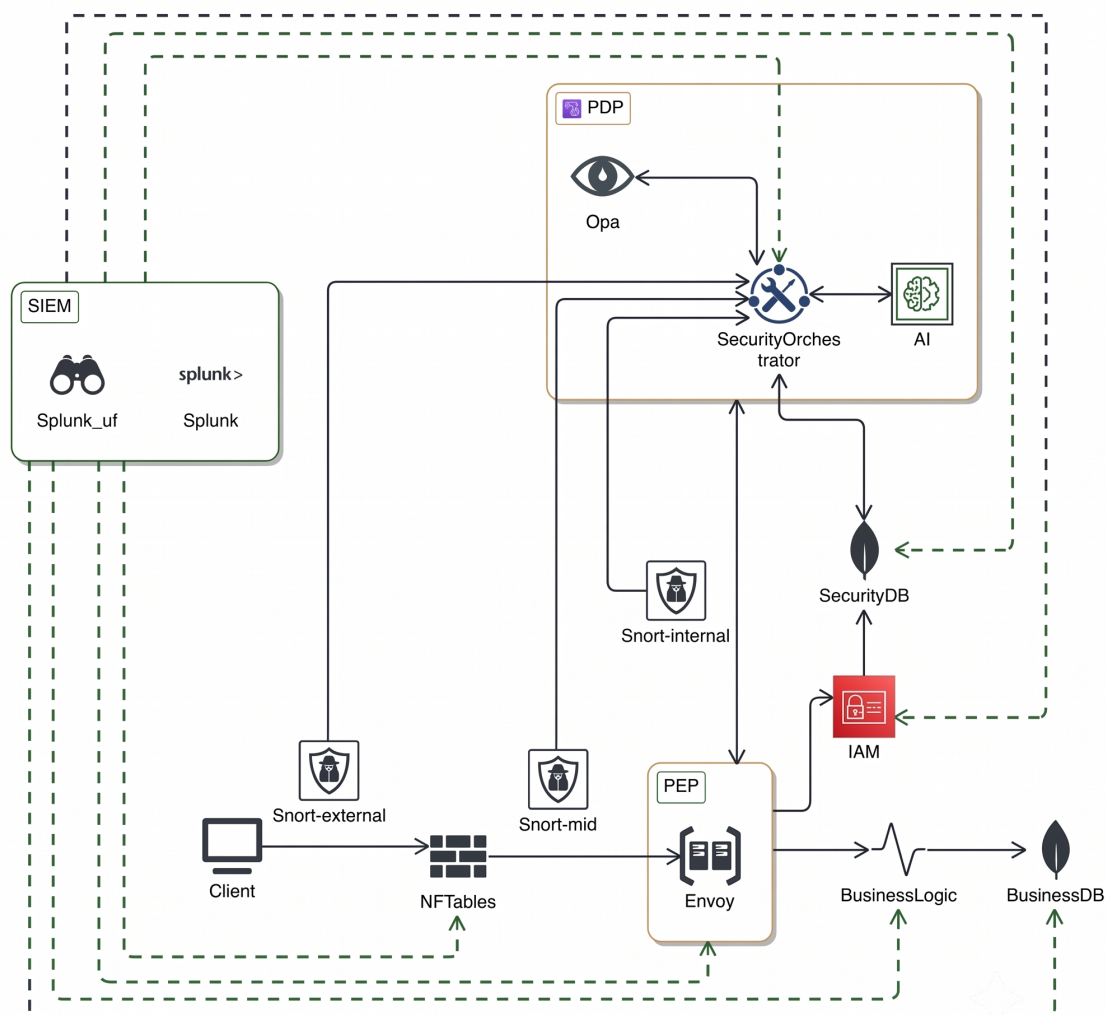


Figura 3.1: Schema dell'architettura generale del sistema.

3.1 Struttura della repository

Il codice sorgente dell'infrastruttura è strutturato per rispecchiare la scomposizione logica del sistema. Le cartelle principali che compongono il progetto sono descritte nell'elenco seguente:

- **api/**: ospita il contratto protocollare `ext_authz.proto`, che costituisce la definizione formale dell'interfaccia di comunicazione tra i sistemi;
- **certs/**: raccoglie i certificati digitali e le chiavi private impiegati per la mutua autenticazione del canale cifrato, includendo i certificati della Certificate Authority interna e lo script di generazione `gen-certs.sh`;
- **deployments/**: racchiude le configurazioni per il deployment dell'infrastruttura, suddividendosi in **docker/**, che contiene il file `docker-compose.yaml` per l'avvio ordinario e `docker-compose.test.yaml` per i test, e **kubernetes/**, che contiene le definizioni per l'orchestrazione dei pod;
- **docs/**: contiene la documentazione tecnica e le guide di riferimento per l'attivazione e la manutenzione dell'infrastruttura;
- **infra/**: ospita i file di configurazione dei servizi infrastrutturali, strutturandosi in **databases/** per MongoDB, **envoy/** per il proxy, **nftables/** per il firewall, **opa/** per le regole di accesso e **snort/** con **snort-internal/** per il rilevamento delle intrusioni;
- **services/**: comprende le implementazioni software dei servizi attivi, includendo **business-logic/** scritto in Go per la gestione dei dati applicativi, **iam-service/** scritto in Go per la gestione delle identità e degli accessi, e **security-orchestrator/** scritto in Go come coordinatore decisionale;
- **tests/**: raccoglie gli strumenti per la convalida dei componenti, comprendendo la cartella **clients/** con simulatori in Python e Go per la generazione di traffico e attacchi;
- **tools/**: ospita utilità di supporto tra cui il seeder del database per la generazione di record coerenti.

La radice della repository ospita il file `.env` con le chiavi di configurazione necessarie, il file `.gitignore` e il file `README.md`.

3.2 La segmentazione di rete

La topologia di rete si articola in 4 segmenti Docker isolati, applicando il controllo degli accessi a livello infrastrutturale. Questa compartimentazione assicura che un compromesso su un servizio non si propaghi ad altri domini.

La **Front-Net** rappresenta l'unico canale rivolto all'esterno. In questo segmento risiedono il firewall di rete, il proxy Envoy e il Security Orchestrator. Qualsiasi richiesta in ingresso deve attraversare questo canale, venendo sottoposta ai controlli del firewall prima di poter raggiungere i servizi interni.

La **Auth-Net** costituisce il segmento privato dedicato alla determinazione delle autorizzazioni. In questa rete cooperano il Security Orchestrator, il motore Open Policy Agent e il database di sicurezza. Il Security Orchestrator funge da unico elemento di connessione tra la **Front-Net** e la **Auth-Net**, impedendo la raggiungibilità diretta del database di sicurezza e del motore delle regole da parte dei client esterni.

La **Back-Net** è una rete protetta e riservata che unisce il servizio di business logic al relativo database di produzione (**business-db**), attestato esclusivamente su questo segmento. Questa separazione assicura che il database contenente i dati sensibili della centrale sia isolato sia dall'esterno sia dallo stesso piano di decisione delle policy: né il Security Orchestrator né OPA dispongono di credenziali o di un percorso diretto verso di esso, e l'unico componente che vi accede è il servizio di Business Logic. Le richieste già autorizzate raggiungono quest'ultimo tramite Envoy, che condivide il namespace di rete del firewall e instrada verso il backend applicativo senza che il database lasci mai la **Back-Net**.

La **Snort-Net** è dedicata esclusivamente al trasporto degli alert dalle 3 istanze Snort verso il Security Orchestrator, descritto nella Sezione 3.10.1, mantenendo il canale di telemetria delle intrusioni separato dai segmenti applicativi.

3.3 Il firewall e il punto di ingresso

Il container denominato **firewall** costituisce la barriera iniziale per il traffico in ingresso. Configurato tramite nftables su una distribuzione Alpine Linux, il firewall adotta una politica predefinita di tipo DROP per le catene di ingresso e uscita.

Per impedire che il traffico possa aggirare i controlli, il proxy Envoy e i sistemi di rilevamento delle intrusioni Snort condividono lo stack di rete del firewall tramite la configurazione **network_mode** di Docker. Questa unione assicura che ogni pacchetto debba superare i controlli a livello kernel prima di essere intercettato da Envoy o ispezionato da Snort.

La configurazione del firewall include regole per contrastare gli attacchi volumetrici di tipo SYN flood tramite una struttura dinamica denominata **syn_meter**, la quale limita a 20 pacchetti al secondo la frequenza per ogni indirizzo IP sorgente, respingendo le eccedenze con il log di avviso **fw-syn-flood-drop**. Inoltre, la catena di uscita implementa un filtraggio rigoroso che consente le sole comunicazioni dirette alle porte TCP di risoluzione dei nomi e ai microservizi interni, ossia le porte 53, 8080, 8081 e 8082, scartando ogni altra richiesta in uscita sotto il log **fw-egress-drop**. Il demone **ulogd** raccoglie questi eventi tramite NFLOG e li scrive su un file in emulazione syslog. Un parser scritto in Go legge questo file e genera un log JSONL strutturato nel percorso **/var/log/ztaleaks/nftables/firewall.jsonl**, rendendolo disponibile per l'inoltro e l'indicizzazione centralizzata.

3.4 Envoy Proxy come Policy Enforcement Point

Il proxy Envoy agisce come Policy Enforcement Point del sistema, operando sulla porta 8443.

Il canale TLS è configurato per richiedere la presentazione facoltativa di un certificato client, demandando la verifica del possesso e la validazione del certificato al Security Orchestrator tramite una chiamata HTTP. In caso di guasto del coordinatore, il sistema applica il principio *Deny by default*. Va segnalata una conseguenza di questa configurazione che merita di essere chiarita rispetto a quanto descritto nella Sezione ??: poiché a livello TLS il certificato è facoltativo, esiste una finestra in cui la connessione TCP/TLS viene stabilita senza alcun certificato client e la richiesta HTTP raggiunge effettivamente il servizio Identity prima che un certificato possa essere validato a livello di trasporto. Il controllo applicativo descritto in quella sezione mitiga il rischio principale: l'handler **Login** verifica la presenza del certificato come primo passo, prima della validazione della password, bloccando con **403 Forbidden** qualunque richiesta priva di certificato per i ruoli diversi da **guest**. Resta comunque un'esposizione residua intrinseca alla scelta architetturale: la connessione TLS viene comunque negoziata e la richiesta HTTP viene comunque ricevuta ed elaborata (seppur respinta) dal servizio applicativo prima che l'identità del client sia stata verificata a livello di trasporto, esponendo superficie d'attacco aggiuntiva (parsing della richiesta, rate limiting, logging) a un client non autenticato che in un'architettura mTLS strettamente enforced a livello TLS non raggiungerebbe mai l'applicazione.

Le informazioni estratte dal certificato client e l'impronta JA3 vengono inserite negli header prima di inviare la richiesta all'orchestratore. I log di accesso di Envoy sono scritti in formato JSONL includendo il valore letterale **service**: `"envoy"`.

3.5 Il Security Orchestrator come Policy Administrator

Il Security Orchestrator opera come Policy Administrator, ricevendo le richieste di valutazione dal proxy Envoy. Questo microservizio, sviluppato in Go, espone un server HTTP sulla porta 8081 e coordina le componenti coinvolte nel processo decisionale.

All'avvio, il servizio configura un logger JSON strutturato che integra il valore **service**: `"security-orchestrator"`. Per ogni richiesta ricevuta sulla rotta `/api/v1/evaluate`, l'orchestratore esegue le seguenti attività:

- estrae il token JWT dall'header di autorizzazione e ne convalida la firma crittografica tramite l'endpoint JWKS esposto dall'identity service;
- identifica il dispositivo analizzando l'header del certificato mTLS e interroga il database di sicurezza per verificare la validità dell'attestazione TPM associata al dispositivo;

- esegue un controllo in modalità trasparente, denominata Shadow Mode, confrontando l'unità organizzativa del certificato con il ruolo dell'utente ed evidenziando eventuali disallineamenti;
- arricchisce il contesto con il punteggio di rischio calcolato da un modello di Intelligenza Artificiale di tipo Temporal Graph Network (TGN), interrogato come micro-servizio esterno: il modello ricostruisce il grafo storico delle interazioni e restituisce un *anomaly score* continuo nell'intervallo $[0, 1]$. Per resistere ad attacchi di tipo *poisoning*, l'interrogazione segue un flusso in 2 fasi: l'orchestratore chiama prima l'endpoint `/infer` in sola lettura per ottenere lo score e, solo se la decisione finale di OPA è di consenso, conferma l'evento nella memoria del modello tramite l'endpoint `/update`, così che gli accessi negati non contribuiscano mai all'addestramento. In caso di indisponibilità o timeout del servizio (5 secondi), l'orchestratore adotta in modo conservativo uno score elevato pari a 0.99 con confidenza `low`, traducendo l'incertezza in una postura più restrittiva;
- compone un documento strutturato e interroga il motore OPA per la decisione definitiva.

Le decisioni emesse vengono registrate in un log dedicato denominato `opa_decision.jsonl` per finalità di ispezione e analisi forense.

3.5.1 Alert provenienti dagli Snort

Parallelamente al flusso di valutazione sincrono, il Security Orchestrator mantiene una cache in memoria degli alert generati dalle istanze Snort. Un listener TCP dedicato, in ascolto sulla porta 9000, riceve dal parser degli IDS gli allarmi serializzati come JSON newline-delimited e li indicizza per indirizzo IP sorgente. Per ciascun IP la cache conserva 3 slot distinti, corrispondenti alle istanze *edge* (`snort`), *mid* (`snort-mid`) e *internal* (`snort-internal`), associati a una scadenza temporale (TTL) di 3 minuti che viene rinnovata a ogni nuovo allarme. Al momento della valutazione di una richiesta, l'orchestratore interroga la cache per l'IP del client e converte la presenza di allarmi recenti in feature binarie, passate al modello TGN insieme agli altri attributi della richiesta (corrispondenza del fingerprint JA3, metodo, ruolo e livello di clearance). In questo modo un'attività di rete sospetta rilevata da Snort innalza in tempo reale lo score di rischio associato alle richieste provenienti dal medesimo indirizzo, senza introdurre latenza aggiuntiva nel percorso decisionale.

3.6 OPA come Policy Decision Point

La policy predefinita applica un approccio *default deny*, bloccando qualsiasi richiesta non esplicitamente autorizzata. La valutazione autorizzativa si articola ad alto livello su una catena di controlli logici sequenziali: la verifica di eventuali esenzioni per le rotte pubbliche, l'assegnazione degli attributi di sicurezza in base all'identità aziendale, la vali-

dazione matematica dell'appartenenza ai compartimenti richiesti (Categorie) e il controllo gerarchico di confidenzialità basato sulle direttive del modello Bell-LaPadula.

A valle dei controlli strutturali, la policy integra la valutazione continua del rischio generata in tempo reale dai sistemi di Intelligenza Artificiale. Invece di affidarsi a soglie di blocco fisse o a meccanismi di fallback statici, il sistema valuta ogni singola transazione attraverso il calcolo di un bilancio di rischio netto: l'accesso viene definitivamente autorizzato solo se il beneficio intrinseco dell'operazione, decurtato dello score di minaccia calcolato dall'AI, risulta superiore al livello di rischio accettato per quello specifico endpoint.

3.7 Il Business Logic service

Il servizio Business Logic rappresenta il backend applicativo che gestisce il dominio operativo della centrale. Il servizio è scritto in Go e popola i propri log integrando il campo `service`: `"business-logic"` per abilitare la correlazione automatica in Splunk.

Un middleware intercetta le richieste in transito, estraendo gli header di tracciamento iniettati da Envoy come `X-Request-ID`, `X-Current-User` e `X-Ja3-Fingerprint`. Questi dati vengono combinati con la durata e lo stato della risposta per produrre un record di log esaustivo.

Per garantire la protezione contro tentativi di manomissione diretta della base dati, il servizio implementa una convalida dell'integrità: all'atto della creazione o dell'aggiornamento di un record sensibile, il sistema calcola un hash SHA-256 concatenando i campi informativi con un carattere di separazione pipe; questo hash viene memorizzato nel documento e ricalcolato a ogni lettura, bloccando la visualizzazione e sollevando un errore qualora si rilevi una divergenza.

3.8 Identity Access Management service

Il servizio Identity Access Management (`iam-service`) gestisce l'intero ciclo di vita dell'autenticazione e dell'identità. È scritto in Go, espone un server HTTP sulla porta 8082 e popola i propri log integrando il campo `service`: `"iam-service"` per la correlazione automatica in Splunk.

L'autenticazione segue un flusso a 2 fasi che incorpora un secondo fattore obbligatorio. Nella prima fase, la rotta `/api/v1/auth/login` verifica le credenziali confrontando la password con un hash Argon2id e controlla il certificato client propagato da Envoy, verificando che il campo CN corrisponda allo username e che l'unità organizzativa corrisponda al ruolo dichiarato. Superati questi controlli, il servizio genera un codice OTP a 6 cifre, ne memorizza l'hash HMAC-SHA256 con una scadenza di 5 minuti e un massimo di 3 tentativi, e lo invia all'indirizzo email registrato. Nella seconda fase, la rotta `/api/v1/auth/verify-otp` valida il codice e, solo in caso di esito positivo, rilascia il token di sessione.

Il token emesso è un JWT firmato con algoritmo RS256, la cui chiave pubblica RSA corrispondente è pubblicata sull'endpoint `/.well-known/jwks.json`, da cui il Security Orchestrator la recupera per verificare in autonomia la firma di ogni token, senza dover condividere segreti con l'iam-service.

Il servizio gestisce inoltre l'elevazione del livello di fiducia del dispositivo. Attraverso le cerimonie WebAuthn/FIDO2, un utente può registrare un dispositivo tramite TPM: la credenziale viene salvata nella collezione `device_fingerprints`.

3.9 I database

L'infrastruttura utilizza 2 database MongoDB separati per impedire la commistione tra dati di sicurezza e informazioni di produzione.

Il Business DB memorizza i dati del personale e della centrale. Il database abilita l'autenticazione obbligatoria e definisce 3 utenze (personnel, manager e admin, descritte in dettaglio nella Sezione 4.8 del Capitolo 4). Nessuna di tali utenze è accessibile dal piano decisionale: né il Security Orchestrator né il motore PDP dispongono di credenziali proprie sul Business DB, in coerenza con il principio di complete mediation discusso nel Capitolo 2, secondo cui non deve esistere un percorso diretto dal piano decisionale verso il database applicativo. Ciascuna delle collezioni è protetta da un JSON Schema che valida i tipi di dato e la coerenza dei formati. I documenti del personale e delle zone includono rispettivamente i sotto-documenti `ztna_metadata` e `ztna_policy` per supportare le verifiche del Policy Decision Point.

Il Security DB è destinato esclusivamente al salvataggio delle impronte digitali dei dispositivi registrati nella collezione `device_fingerprints` e degli utenti abilitati nel servizio di identità, rimanendo accessibile solo all'orchestratore e al servizio di identità.

3.10 Il sistema di rilevamento delle intrusioni

Il monitoraggio della sicurezza di rete si avvale di 3 istanze distinte di Snort, posizionate strategicamente all'interno dell'infrastruttura per ispezionare il traffico a diversi livelli:

- *istanza esterna* (`snort`): analizza il traffico in ingresso sulla **Front-Net**;
- *istanza interna* (`snort-internal`): analizza le transazioni interne dirette verso il proxy Envoy, cercando violazioni del canale TLS;
- *istanza mid* (`snort-mid`): ispeziona il traffico applicativo in transito tra Envoy e il Security Orchestrator (sul canale `ext_authz`).

3.10.1 Meccanismo di inoltro degli alert

Affinché le minacce vengano gestite tempestivamente, le istanze IDS sono collegate a un sistema di telemetria in tempo reale. Un parser personalizzato scritto in Go legge i log generati dalle 3 istanze di Snort in modalità *tailing*, normalizzandoli in formato JSONL.

Una volta normalizzato, ogni evento critico viene immediatamente inoltrato al Security Orchestrator.

3.11 Il flusso di autorizzazione end-to-end

La cooperazione tra i componenti può essere compresa seguendo il percorso di una transazione, illustrato nella catena di passaggi descritta di seguito:

- il client effettua la chiamata verso la porta **8443** di Envoy, attraversando le regole del firewall che verificano l'assenza dell'indirizzo sorgente dalla lista nera e valutano i limiti di frequenza;
- Envoy instaura la sessione TLS raccogliendo i dati del certificato client e l'impronta JA3, inviando poi una chiamata HTTP al Security Orchestrator con i dettagli della transazione;
- il Security Orchestrator valida il token JWT tramite JWKS, verifica l'attestazione TPM sul database di sicurezza e arricchisce la richiesta con il punteggio del rischio calcolato dai sistemi di Intelligenza Artificiale;
- OPA riceve l'input arricchito dall'orchestratore, valuta la policy multi-dimensionale e restituisce il verdetto finale;
- se OPA consente l'accesso, l'orchestratore autorizza Envoy, il quale inoltra la richiesta al Business Logic; quest'ultimo convalida l'integrità dei record tramite SHA-256 e risponde al client includendo l'identificativo **X-Request-ID** per la correlazione centralizzata dei log.

4 Implementazione dei componenti

Dopo aver delineato nel capitolo precedente la struttura generale dell'architettura e il flusso di autorizzazione end-to-end, l'attenzione viene ora focalizzata sull'analisi dettagliata di ciascun componente. L'obiettivo di questo capitolo è esaminare in profondità il funzionamento interno di ogni modulo del sistema, illustrando le scelte implementative, i meccanismi crittografici, le strutture dati e le interazioni reciproche tra i servizi. Si procede seguendo il percorso che una richiesta compie attraversando l'infrastruttura, partendo dal firewall di rete e giungendo fino al database applicativo, in modo da costruire una comprensione progressiva e coerente dell'intero sistema.

4.1 Il firewall di rete con nftables

Il primo componente che intercetta il traffico in ingresso è il container `ztaleaks_firewall`, costruito su un'immagine Alpine Linux minimale e configurato per eseguire `nftables` come sistema di filtraggio dei pacchetti. Questo container svolge un duplice ruolo nell'architettura: da un lato applica una policy di filtraggio rigorosa sul traffico in ingresso, dall'altro fornisce lo stack di rete condiviso per i container Envoy e le 3 istanze Snort, che sono configurati con la direttiva `network_mode:service:firewall` nel file di Compose.

Questa scelta architetturale ha conseguenze rilevanti sulla sicurezza. Il fatto che Envoy e le istanze Snort condividano il namespace di rete del firewall significa che ogni pacchetto destinato a Envoy attraversa obbligatoriamente le catene di nftables prima di raggiungere il proxy, e che Snort osserva esattamente lo stesso flusso di traffico che Envoy riceve. Non esiste alcun percorso alternativo: la complete mediation è garantita a livello del kernel Linux, senza affidarsi a configurazioni applicative che potrebbero essere aggirate.

La configurazione di `nftables` è definita nel file `nftables.conf` montato all'interno del container. La tabella principale è denominata `inet filter` e gestisce sia il traffico IPv4 sia quello IPv6 in modo unificato. All'interno della tabella vengono definite 5 catene: 3 catene IDS dedicate al dirottamento del traffico verso le istanze Snort tramite NFQUEUE, e le catene tradizionali `input` e `output`.

Catene IDS con NFQUEUE

Prima di raggiungere le catene di filtraggio, il traffico transita attraverso 3 catene IDS configurate con priorità negative, in modo da eseguire l'ispezione Snort prima di qualsiasi decisione di filtraggio. La direttiva `bypass` garantisce il comportamento fail-open: se un'istanza Snort si arresta, il kernel accetta il pacchetto invece di scartarlo, mantenendo operativo il sistema. Le istanze Snort operano in modalità pura IDS, emettendo solo verdetti `ACCEPT`, senza mai bloccare il traffico autonomamente.

Le 3 catene IDS sono le seguenti:

- La catena `ids_prerouting`, con priorità `-150`, intercetta tutto il traffico in ingresso sull'interfaccia di rete esterna (`front-net`) e lo dirige verso la coda numero 1, dove opera l'istanza Snort esterna che rileva attività di scansione e ricognizione.
- La catena `ids_prerouting_tls`, con priorità `-140`, intercetta il solo traffico TCP diretto alla porta di Envoy e lo dirige verso la coda numero 2, dove opera l'istanza Snort interna che analizza le anomalie TLS e i tentativi di SYN flood.
- La catena `ids_output_extauthz`, con priorità `-150` sul hook `output`, intercetta il traffico TCP diretto alla porta 8081 del Security Orchestrator e lo dirige verso la coda numero 3, dove opera l'istanza Snort intermedia che rileva attacchi applicativi (SQL injection e XSS) sul canale `ext_authz` in chiaro.

Catene di filtraggio

La catena `input` è configurata con policy di default DROP. Questa scelta rappresenta l'applicazione del principio di fail-safe defaults: in assenza di una regola esplicita di consenso, il pacchetto viene scartato silenziosamente. Le regole di consenso sono limitate al minimo necessario: viene accettato il traffico locale sull'interfaccia di loopback, il traffico appartenente a connessioni già stabilite o correlate (sfruttando il connection tracking del kernel) e il traffico TCP nuovo verso la porta di Envoy, loggato con il prefisso `fw-accept`. Il traffico non ammesso che raggiunge il fondo della catena viene scartato e registrato, con logging limitato in frequenza (`rate 10/second`), sotto il prefisso `fw-input-drop`.

Un meccanismo di rilievo è rappresentato dal controllo anti-SYN flood: tramite un contatore dinamico denominato `syn_meter`, le connessioni con flag SYN che superano la frequenza di 20 richieste al secondo per singolo indirizzo IP sorgente vengono scartate e registrate nei log con il prefisso `fw-syn-flood-drop`.

La catena `output` implementa anch'essa una policy di default DROP per impedire connessioni non autorizzate verso l'esterno. La allow-list di uscita comprende il traffico di loopback, le connessioni già stabilite, le porte TCP dei servizi applicativi (8080, 8081, 8082), la porta del socket TCP Snort verso l'orchestratore (9000), le porte per la risoluzione DNS (53 TCP e UDP), la porta MongoDB (27017) e la porta syslog (1025). Le connessioni in uscita ammesse sono registrate con il prefisso `fw-egress-accept`, mentre ogni altra viene rifiutata e registrata sotto `fw-egress-drop`; entrambi i log sono limitati in frequenza per evitare flooding del log.

Avvio e configurazione a runtime

Lo script `entrypoint.sh` orchestra l'avvio del container in 6 fasi sequenziali: crea le directory di log, avvia `ulogd` in background, sostituisce nella configurazione le 2 variabili segnaposto `ENV_ENVOY_PORT` e `ENV_FRONT_IFACE` con i valori effettivi prelevati dall'ambiente (la seconda viene risolta dinamicamente interrogando la subnet `FRONT_NET_SUBNET` tramite il comando `ip`), carica le regole nel kernel tramite `nft delete table` seguito da

`nft -f`, avvia il parser Go in background e infine mantiene il container attivo in foreground effettuando un tail del file di log.

Il logging è gestito dal demone `ulogd`, configurato con uno stack di plugin che riceve gli eventi dal gruppo NFLOG numero 100, li arricchisce con metadati di rete e li scrive sul file `ulogd-syslogemu.log`. Il parser Go (`parser.go`) legge tale file in modalità `tail -F` (resistente alla rotazione dei log), estrae i campi chiave-valore dal formato syslog, identifica il prefisso del log (es. `fw-accept`, `fw-input-drop`, `fw-syn-flood-drop`, `fw-egress-accept`, `fw-egress-drop`) e produce record JSON strutturati con campi `action` e `threat`, scritti in append sul file `firewall.jsonl` all'interno del volume condiviso con il Splunk Universal Forwarder.

4.2 Il sistema di rilevamento intrusioni con Snort

Sul medesimo stack di rete del firewall operano 3 container Snort distinti, ciascuno collegato a una coda NFQUEUE specifica e dedicato a un livello di ispezione differente. I 3 container sono denominati `ztaleaks_snort` (coda 1), `ztaleaks_snort_internal` (coda 2) e `ztaleaks_snort_mid` (coda 3), e svolgono funzioni complementari nell'architettura di rilevamento.

Tutte e 3 le immagini sono costruite con un processo multi-stage: il primo stage compila in Go il parser degli alert, mentre il secondo stage installa Ubuntu 24.04 con Snort 2.9 dai repository ufficiali e incorpora il binario compilato. Snort viene avviato con i flag `-k none` per disabilitare la verifica dei checksum (necessaria sulle interfacce virtuali Docker), `-A fast` per il formato di output degli alert, e `-daq nfq -daq-var queue=N` per l'integrazione NFQUEUE.

Istanza esterna (coda 1): scansioni di porte

Il container `ztaleaks_snort` monitora tutto il traffico in ingresso sull'interfaccia `front-net`. Il preprocessore `sfportscan` è abilitato con i parametri `proto {all}`, `memcap {10000000}` e `sense_level {low}` per minimizzare i falsi positivi. L'unica regola nel file `portscan.rules` (SID 1000001) genera l'alert *ZTA: TCP Port Scanning Detected* quando vengono rilevati più di 5 pacchetti TCP con flag SYN dalla stessa sorgente nell'arco di 5 secondi, con classificazione `attempted-recon`.

Istanza interna (coda 2): anomalie TLS

Il container `ztaleaks_snort_internal` monitora il traffico TCP diretto alla porta di Envoy, specializzandosi nell'ispezione dei record TLS. Il file `internal.rules` implementa un insieme articolato di regole suddivise in 3 sezioni:

- *Anomalie mTLS*: la regola SID 2000002 individua la violazione mTLS cercando il pattern binario `0B 00 00 03 00 00 00`, corrispondente a un messaggio Certificate di tipo `HandshakeType=11` con lista di certificati vuota, indicativo dell'assenza del

certificato client. Una regola ICMP canary (SID 1000004) viene usata durante i test di integrazione per verificare che l'IDS sia attivo.

- *Versioni TLS legacy*: 3 regole (SID 2000010–2000012) rilevano l'offerta di SSLv3, TLS 1.0 e TLS 1.1 nel campo `legacy_version` del ClientHello (offset 9–10 del payload), scelto deliberatamente rispetto alla versione del record TLS (bytes 1–2) per evitare falsi positivi sulle connessioni TLS 1.3, che impostano la versione del record a 0x0301 per compatibilità. 3 ulteriori regole (SID 2000020–2000022) rilevano i corrispondenti attacchi di downgrade nel ServerHello.
- *Cipher suite deboli*: 3 regole (SID 2000030–2000032) rilevano cipher suite RC4, 3DES e NULL/EXPORT/DH anonime offerte nel ClientHello, utilizzando espressioni regolari PCRE ancorate alla posizione relativa dopo l'intestazione del messaggio.
- *SYN flood*: la regola SID 2000006 genera un alert quando un singolo destinatario riceve più di 30 pacchetti SYN nell'arco di 2 secondi verso la porta di Envoy, con classificazione `attempted-dos`.

Istanza intermedia (coda 3): attacchi applicativi

Il container `ztaleaks_snort_mid` monitora il traffico TCP tra Envoy e il Security Orchestrator sulla porta 8081, ispezionando il canale `ext_authz` in chiaro. Il file `mid.rules` implementa 2 categorie di rilevamento:

- *SQL Injection* (SID 3000001–3000004): 4 regole rilevano rispettivamente il pattern `UNION SELECT`, la tautologia `OR 1=1`, l'istruzione `DROP TABLE` e la tautologia URL-encoded `%27 OR ... %3D`.
- *Cross-Site Scripting* (SID 3000010–3000014): 5 regole rilevano i tag `<script>` in forma grezza e URL-encoded, lo schema URI `javascript:` e i gestori di eventi `onerror=` e `onload=`.

Parser e integrazione con l'orchestratore

Ogni istanza Snort esegue in background un parser Go condiviso (`parser.go`) che legge il file degli alert in formato `fast` e applica un'espressione regolare per estrarre i campi strutturati di ciascun alert: timestamp, messaggio, classificazione, priorità, indirizzo e porta sorgente, indirizzo e porta di destinazione. Gli alert strutturati vengono scritti come JSON su un file JSONL specifico del container e trasmessi in tempo reale al Security Orchestrator tramite una connessione TCP persistente sulla porta 9000, dove vengono inseriti nella `SnortCache` con TTL di 3 minuti per alimentare la valutazione del rischio.

4.3 Envoy Proxy e la pipeline TLS

Concluso il livello di filtraggio e ispezione IDS, il traffico raggiunge Envoy, il componente più articolato dell'architettura dal punto di vista della configurazione. Il file `envoy.yaml`, montato nel container all'avvio, definisce in modo dichiarativo l'intera pipeline di terminazione TLS, intercezione delle richieste, delega dell'autorizzazione e instradamento verso i backend.

La sezione `static_resources` contiene la configurazione dei listener e dei cluster, ovvero rispettivamente i punti di ingresso del traffico e i gruppi di endpoint upstream verso cui le richieste vengono instradate.

Il listener principale, denominato `listener_0`, si pone in ascolto sulla porta 8443 e applica come primo filtro di livello listener il `tls_inspector`, configurato con la direttiva `enable_ja3_fingerprinting: true`. Questo filtro analizza i parametri dell'handshake TLS prima ancora che la negoziazione sia completata, calcolando l'impronta JA3 del client e rendendola disponibile come variabile di metadato attraverso il placeholder `%TLS_JA3_FINGERPRINT%`.

La catena di filtri prosegue con il `transport_socket` di tipo `DownstreamTlsContext`, che gestisce la terminazione TLS. La configurazione carica il certificato server, la chiave privata e il certificato della CA interna dai percorsi `/etc/envoy/certs/`. Il parametro `require_client_certificate` è impostato su `false` per consentire l'accesso iniziale agli utenti non ancora in possesso di un certificato client, lasciando al livello superiore la valutazione dei requisiti di sicurezza.

Completato l'handshake TLS, il controllo passa al filtro di rete `http_connection_manager`. La direttiva `use_remote_address: true` abilita il popolamento dell'header `x-forwarded-for` con l'indirizzo IP reale del client downstream, con una configurazione esplicita degli intervalli di indirizzi interni per la corretta classificazione del traffico. La direttiva `forward_client_cert_details: SANITIZE_SET` garantisce che l'header `x-forwarded-client-cert` venga sempre sovrascritto con il valore derivato dalla connessione TLS effettiva, prevenendo attacchi di spoofing.

La configurazione degli access log prevede un doppio output: uno verso lo standard output (per i log Docker) e uno verso il file `access.jsonl` all'interno del volume condiviso. Il formato dei log è JSON strutturato e include i campi per la correlazione: l'identificatore `request_id` (propagato dall'header `X-Request-ID`), l'impronta JA3, l'indirizzo remoto, il cluster upstream, il certificato client e l'identità dell'utente autenticato.

La sezione `request_headers_to_add` inietta automaticamente 3 header nelle richieste: `x-ja3-fingerprint` con il valore dell'impronta JA3, `x-original-uri` con il path originale della richiesta e `x-envoy-external-address` con l'indirizzo IP esterno del client, derivato dall'indirizzo downstream reale e non falsificabile dal client.

La pipeline dei filtri HTTP comprende 2 elementi in sequenza. Il primo è il filtro `ext_authz`, che effettua una chiamata sincrona di autorizzazione al Security Orchestrator sull'endpoint `/api/v1/evaluate` con un timeout di 5 secondi. La direttiva `failure_mode_`

`allow: false` garantisce il comportamento fail-closed (Zero Trust). Il filtro trasmette al Security Orchestrator un insieme definito di header tra cui `authorization`, `x-forwarded-client-cert`, `x-ja3-fingerprint`, `x-original-uri`, `x-zone-id` e `x-envoy-external-address`, e riceve in risposta gli header `x-current-user`, `x-risk-score` e `x-envoy-external-address` che vengono propagati all'upstream. Il secondo filtro è il `router`, che completa l'instradamento.

4.4 Il Security Orchestrator

Il Security Orchestrator costituisce il punto di raccordo decisionale del sistema, scritto in Go e strutturato per operare come server HTTP sulla porta 8081. Il punto di ingresso si trova nel file `cmd/orchestrator/main.go`.

All'avvio, il programma configura un logger JSON strutturato che scrive sia su stdout sia su file (`app.jsonl`) all'interno del volume dedicato, con il valore di provenienza prepopolato `service: "security-orchestrator"`. Esso si connette al database di sicurezza leggendo i parametri di connessione dall'ambiente, inizializza i client per le varie componenti (verifier JWT, lookup TPM, client OPA, client AI) e crea la cache degli alert Snort con TTL di 3 minuti.

Il servizio espone 3 handler principali: l'endpoint `/health` per la verifica dello stato di salute, l'endpoint `POST /api/v1/opa/logs` dedicato alla ricezione e memorizzazione in append dei log decisionali compressi provenienti da OPA all'interno del file `opa_decision.jsonl` (che gestisce anche la decompressione gzip), e l'handler principale di valutazione montato su `/api/v1/evaluate` e come catch-all radice.

In parallelo al server HTTP, viene avviato un listener TCP sulla porta 9000 (configurabile tramite la variabile `SNORT_ALERTS_TCP_PORT`) tramite il modulo `snortlistener`. Questo listener riceve gli alert JSON line-delimited trasmessi in tempo reale dai parser Snort e li popola nella `SnortCache`, indicizzata per indirizzo IP sorgente con 3 campi distinti: `AlertEdge` (coda 1), `AlertInternal` (coda 2) e `AlertMid` (coda 3).

L'handler di valutazione, costruito tramite la funzione `BuildEvaluateHandler` definita in `handler.go`, esegue una sequenza strutturata di operazioni per ogni richiesta ricevuta:

- Ricostruisce il percorso originale della richiesta consultando gli header `X-Original-Uri`, `X-Authz-Request-Path` o il path della richiesta corrente, ed estrae il metodo HTTP. L'indirizzo IP del client viene ricavato dall'header `x-envoy-external-address` (prodotto da Envoy con `use_remote_address: true` e non falsificabile), con fallback all'ultimo elemento di `X-Forwarded-For`.
- Verifica la presenza di un Bearer token nell'header `Authorization`. Se il token è assente, esegue comunque l'analisi di conformità del dispositivo (Shadow Mode) per tracciamento, costruisce un input base e interroga OPA per verificare se la risorsa è pubblica.

- Se il token è presente, ne valida l'integrità e la firma crittografica interrogando il componente `jwtpkg.Verifier` che scarica dinamicamente le chiavi pubbliche dall'endpoint `JWKS` dell'identity service.
- Analizza il certificato mTLS client eventualmente inoltrato da Envoy nell'header `X-Forwarded-Client-Cert` tramite il modulo `cert`.
- Interroga in sola lettura la collezione `device_fingerprints` del database di sicurezza tramite il modulo `tpm` per verificare la presenza di una registrazione hardware associata al dispositivo dell'utente.
- Conduce una verifica di conformità del dispositivo in modalità trasparente (Shadow Mode) tramite la funzione `evaluateStrictDeviceFingerprinting`: confronta CN e OU del certificato con i dati del database, controlla gli alert Snort attivi nella cache per l'IP del client (e per l'IP di Envoy, per gli alert di tipo `mid` sul canale `ext_authz`), e registra ogni discrepanza senza bloccare il flusso operativo.
- Costruisce l'evento AI con un vettore di feature che include la consistenza JA3, la presenza di alert Snort per ciascuna delle 3 code, il metodo HTTP, il ruolo e il livello di clearance dell'utente e il tier di autenticazione. Invia l'evento al client del sistema di intelligenza artificiale (`aiscorer.Client`) tramite una chiamata HTTP all'endpoint `/infer` del microservizio `ai-inference` per ottenere lo score di anomalia. In caso di timeout o errore di rete il client restituisce un punteggio di fallback `0.99` con confidenza bassa. Se la decisione OPA è positiva, l'evento viene committato nel modello tramite una chiamata asincrona all'endpoint `/update` (meccanismo anti-poisoning).
- Compone il payload strutturato `opa.Input` includendo il metodo, il percorso, i claim del token, i flag di presenza del certificato e del TPM, i metadati geografici della risorsa (`zone_id`), il punteggio e la confidenza dell'AI, e il contesto temporale e di rete (indirizzo IP del mittente, ora del giorno, giorno della settimana e anzianità della sessione in secondi).
- Invia la richiesta al motore OPA. In caso di errore del motore di policy, l'orchestratore applica una logica fail-closed restituendo uno status `403`; in caso di esito positivo, risponde a Envoy con uno status `200` e inserisce gli header `x-current-user` e `x-envoy-external-address` per propagare l'identità dell'utente verificato e il suo IP al backend; in caso di diniego, restituisce uno status `403`.

4.5 Open Policy Agent e la policy in Rego

Il motore Open Policy Agent valuta la policy definita in `infra/opa/policy.rego`. La policy dichiara l'uso della sintassi recente tramite `import rego.v1` all'interno del package `envoy.authz`.

La policy adotta un approccio fail-closed configurando come prima istruzione la direttiva `default allow := false`. L'architettura della policy è organizzata in 5 sezioni principali più il mapping tra i ruoli aziendali e i livelli e categorie del modello Bell-Lapadula.

Sezione 1 — Rotte pubbliche. Un primo insieme di percorsi tecnici (`/health`, `/.well-known/jwks.json`, `/favicon.ico`) vengono autorizzati incondizionatamente senza alcuna valutazione AI. Un secondo insieme di percorsi pubblici (`public_paths`), che include le rotte di autenticazione, le pagine UI e gli endpoint WebAuthn anonimi, viene autorizzato condizionalmente solo se il beneficio (fissato a 0.8) meno il punteggio AI (fissato in caso di anomalie del modello a 0.99) è maggiore del beneficio minimo delle rotte pubbliche fissato a 0.4.

Sezione 2 — Matrice di sicurezza. Per le risorse protette, l'autorizzazione si basa su una struttura dati `matrice_sicurezza` che associa a ciascuna rotta base una classificazione (INTERNAL, SECRET ecc) e una categoria (hr, nuclear ecc) e per metodo HTTP disponibile 2 parametri: `benefici` (valore numerico che riduce il rischio effettivo) e `beneficio_netto_minimo` (soglia minima di beneficio)

Sezione 3 — Risoluzione dinamica della rotta. La policy implementa un meccanismo di risoluzione della rotta base (`rotta_base`) che gestisce le sottorotte con parametri di percorso: una richiesta verso `/api/v1/documents/abc123` viene ricondotta alla rotta base `/api/v1/documents` applicando un confronto per prefisso. In presenza di più rotte compatibili, viene selezionata quella con il prefisso più lungo (match più specifico).

Sezione 4 - Definizione Proprietà Bell-Lapadula Vengono codificate le funzioni di controllo definite dal modello Bell-Lapadula: `*-Property` (No Write-Down standard) , `Simple Security Property` (No Read-Up) e l'eccezione per la rotta sanificata.

Sezione 5 — Regola di autorizzazione. La regola principale concede l'accesso se sono soddisfatte 3 condizioni:

1. Controllo se l'utente possiede l'accesso alla risorsa tramite il campo categoria
2. Controllo delle proprietà del modello di Bell-Lapadula
3. Controllo Rischio AI tramite la formula: $(\text{config_metodo.benefici} - \text{ai_score}) \geq \text{config_metodo.beneficio_netto_minimo}$

4.6 Il servizio Identity

Il servizio Identity gestisce l'autenticazione a 2 fattori degli utenti e l'enrollment dei dispositivi hardware. Scritto in Go, il punto di avvio risiede in `cmd/identity/main.go`.

All'avvio, il servizio inizializza un logger JSON strutturato che scrive nel file `identity_events.json` inserendo il tag di servizio `"identity-service"`, si connette al database di sicurezza tramite il modulo `config.LoadConfig()`, istanzia il gestore JWT (`crypto.JWTManager`) basato su chiavi RSA asimmetriche e configura il client SMTP per

l'invio degli OTP. In background, un ticker ogni 5 minuti esegue la pulizia delle sessioni di rate limit scadute.

Il routing, descritto nel file `routes.go`, definisce la struttura degli endpoint del servizio.

Il sistema prevede due percorsi di autenticazione, selezionati sulla base del livello di privilegio dell'utente:

1. **Autenticazione di base:** credenziali testuali (username e password) + OTP via email (2FA).
2. **Autenticazione avanzata:** username + firma crittografica hardware con chip TPM via FIDO2/WebAuthn + OTP via email (step-up).

4.6.1 Autenticazione di base

Dopo che il client invia le credenziali (Username e Password) il server esegue le seguenti operazioni:

1. **Controllo del rate limit:** il server recupera l'IP reale del client dall'intestazione `X-Envoy-External-Address` (iniettata e non falsificabile da Envoy). In caso di superamento della soglia di tentativi falliti, la richiesta è rifiutata con `HTTP 429 Too Many Requests`.
2. **Ricerca dell'utente nel database:** se l'utente non è trovato, il server esegue comunque l'hashing di una password fittizia (*dummy*) con Argon2id, al fine di rendere il tempo di risposta indistinguibile da quello di un utente esistente con password errata (*timing attack mitigation*).
3. **Verifica del certificato mTLS:** il server esamina l'intestazione `X-Forwarded-Client-Cert`, iniettata da Envoy in seguito all'handshake TLS mutuale. Si distinguono due casi:
 - *Certificato assente:* accettato solo se l'utente ha ruolo `guest`. Per ruoli elevati, il login è immediatamente rifiutato con `HTTP 403 Forbidden`.
 - *Certificato presente:* il server estrae il *Common Name* (CN) e la *Organizational Unit* (OU) dal Subject del certificato. Verifica che:
 - (a) CN coincida con l'username (case-insensitive);
 - (b) OU coincida con il ruolo dell'utente nel database (case-insensitive).Il mancato rispetto di uno dei due vincoli causa il rifiuto con `HTTP 403 Forbidden`.
4. **Verifica della password:** il server decodifica i parametri Argon2id dall'hash MCF memorizzato, ricalcola il digest con il sale originale e confronta il risultato con il valore atteso mediante `subtle.ConstantTimeCompare`, che opera in tempo costante rispetto al contenuto degli operandi, prevenendo attacchi di tipo timing.

5. **Generazione e invio dell'OTP:** in caso di successo, viene generato un codice OTP a 6 cifre e un `session_token` opaco che correla questa fase con la verifica successiva. L'OTP è inviato via email all'utente in modo asincrono.
6. **Reset del rate limit**

Risposta del Server (Server → Client)

Campo	Tipo	Descrizione
<code>status</code>	<code>string</code>	Valore fisso " <code>otp_required</code> "
<code>session_token</code>	<code>string</code>	Token opaco per correlare la fase OTP
<code>message</code>	<code>string</code>	Messaggio informativo

Verifica OTP ed Emissione del JWT

Il client invia `session_token` e codice OTP (ricevuto via email) all'endpoint `POST /api/v1/auth/verify-otp`. Il server verifica l'OTP in modo atomico, prevenendo race condition sul contatore dei tentativi. In caso di successo recupera l'eventuale `credential_id` TPM dell'utente e procede all'emissione del JWT (descritta nella sezione 4.6.4).

4.6.2 Registrazione TPM

Il client, già autenticato tramite Autenticazione base, invia una richiesta al server. La richiesta non trasporta un corpo JSON. L'identità dell'utente è ricavata dall'intestazione `X-Current-User`, iniettata e firmata in *HMAC* dalla Security Orchestrator dopo aver validato il JWT Bearer.

Il server esegue i seguenti controlli:

1. Il server recupera il profilo utente dal database e carica le eventuali credenziali `WebAuthn` già registrate, al fine di costruire la lista di esclusione (*excludeCredentials*), che impedisce il doppio enrollment dello stesso autenticatore.
2. Il server invoca la libreria `go-webauthn` in modalità `BeginRegistration` con le seguenti impostazioni:
 - **AttestationConveyancePreference:** `direct` (il client deve restituire un attestation object completo, che permette di verificare il produttore e il modello dell'autenticatore hardware).
 - **UserVerification:** `required` (il chip TPM deve verificare localmente l'utente, ad esempio tramite PIN o biometria).
3. La libreria genera una **challenge** casuale a 256 bit, la incapsula in un oggetto `SessionData` e la associa a un identificativo di sessione (`session_id`) opaco da 128 bit. Tali dati sono persistiti nel database con TTL di 5 minuti.

4. Il server manda `PublicKeyCredentialCreationOptions` (include `challenge`, `rpId`, `userId`, `timeout`, `excludeCredentials`, `authenticatorSelection`) e il `session_id`

Elaborazione del Chip TPM (lato client)

Dopo aver ricevuto la risposta del *begin*, il browser (tramite la *Web Authentication API*) delega la generazione della coppia di chiavi al chip TPM. Il TPM esegue le seguenti operazioni interne:

1. **Generazione della coppia di chiavi:** il TPM genera una coppia di chiavi asimmetrica (tipicamente ECDSA su P-256 o RSA) all'interno del proprio confine crittografico sicuro. La chiave privata non lascia mai il chip in forma leggibile: è protetta dalla *Endorsement Key* (EK) e dalla *Storage Root Key* (SRK) della gerarchia TPM.
2. **Calcolo dell'`authenticatorData`:** il TPM costruisce la struttura `authenticatorData`, che include:
 - hash SHA-256 del *Relying Party ID* (`rpIdHash`);
 - *flags*: UP (User Present), UV (User Verified, richiesto dalla policy del server);
 - *signCount*: contatore monotono di utilizzo, incrementato ad ogni firma, che consente il rilevamento di authenticatori clonati;
 - *AAGUID*: identificativo del modello di autenticatore (16 byte), che consente di verificare il produttore;
 - chiave pubblica in formato COSE (*CBOR Object Signing and Encryption*).
3. **Costruzione dell'`Attestation Object`:** il TPM produce un *attestation object* in formato CBOR, contenente:
 - `fmt`: formato dell'attestazione (es. "packed");
 - `authData`: l'`authenticatorData` sopra descritto;
 - `attStmt`: la firma dell'attestazione, calcolata dal TPM sull'hash SHA-256 della concatenazione `authData||SHA256(clientDataJSON)` usando la chiave privata di attestazione del chip.
4. **Costruzione del `clientDataJSON`:** il browser (non il TPM) costruisce un oggetto JSON contenente il tipo dell'operazione ("`webauthn.create`"), la challenge ricevuta in base64url e l'origin della richiesta. Questo oggetto lega la risposta crittograficamente alla sessione specifica e impedisce attacchi di replay.

Richiesta del Client (Client → Server)

Il client invia al server, nel corpo della richiesta, un oggetto `AuthenticatorAttestationResponse` in formato JSON (standard W3C WebAuthn), contenente:

Campo	Descrizione
<code>id</code>	Credential ID in base64url
<code>rawId</code>	Credential ID in binario
<code>response.clientDataJSON</code>	JSON che include tipo, challenge e origin
<code>response.attestationObject</code>	Attestation object CBOR-codificato
<code>type</code>	Valore fisso "public-key"

Elaborazione Server-Side e Verifica Crittografica

Il server delega la verifica alla libreria `go-webauthn`, che esegue la seguente sequenza di controlli:

1. Recupero del `session_id` dalla query string e verifica dell'esistenza della challenge corrispondente nel database.
2. Decodifica CBOR dell'attestation object.
3. Verifica che il tipo del `clientDataJSON` sia `"webauthn.create"` e che la challenge al suo interno corrisponda a quella generata in fase *begin*.
4. Verifica dell'origin e dell'`rpIdHash`.
5. Verifica della firma dell'attestazione sul payload `authData||SHA256(clientDataJSON)`.
6. Verifica dell'*attestation statement*: il server accerta che la chiave di attestazione sia genuina e riferibile al produttore dell'autenticatore, tramite la catena di certificati dell'*Attestation Certificate* (formato *packed*).

4.6.3 Login TPM

(Autenticazione Avanzata)

Il client invia l'username ed il server applica il controllo del rate limit sull'IP del client. Ricerca l'utente nel database e carica le credenziali WebAuthn registrate.

Protezione anti user-enumeration: se l'utente non esiste, non è attivo o non ha dispositivi enrollati, il server non restituisce un errore differenziato. Genera invece una *cerimonia fittizia* ("decoy") strutturalmente identica a quella reale, impedendo l'enumerazione delle identità tramite analisi delle risposte. La sessione sarà rifiutata nel *finish* come una firma errata.

In caso di utente valido con dispositivi registrati, il server invoca `go-webauthn.BeginLogin` con `UserVerification: required`, genera una challenge casuale a 256 bit, la persiste nel database (`ceremony_type: "authentication"`, TTL 5 minuti) e associa un `session_id` opaco.

Risposta del Server (Server → Client)

Campo	Descrizione
<code>publicKey</code>	Struttura <code>PublicKeyCredentialRequestOptions</code> (include challenge, rpId, timeout, allowCredentials, userVerification)
<code>session_id</code>	Token opaco per correlare begin e finish

Firma Hardware e Completamento (Finish)

Elaborazione del Chip TPM (lato client) Dopo aver ricevuto la challenge dal server, il browser delega l'operazione al chip TPM. Il TPM esegue le seguenti operazioni interne:

1. **Selezione della chiave privata:** il TPM individua la chiave privata corrispondente al Credential ID incluso in `allowCredentials`, protetta all'interno del confine crittografico del chip. La chiave privata non è mai esportata.
2. **Calcolo dell'authenticatorData:** il TPM costruisce la struttura che include:
 - `rpIdHash`: SHA-256 del Relying Party ID;
 - `flags`: UP (User Present) e UV (User Verified), attestando che l'utente ha superato la verifica locale (PIN, biometria);
 - `signCount`: incrementato di uno rispetto all'ultima autenticazione registrata, consentendo il rilevamento di clonazione.
3. **Costruzione e firma dell'assertion:** il TPM firma crittograficamente il payload:

$$\sigma = \text{Sign}_{sk}(\text{authData} \parallel \text{SHA256}(\text{clientDataJSON}))$$

dove sk è la chiave privata associata alla credenziale e `clientDataJSON` include la challenge ricevuta dal server, il tipo (`"webauthn.get"`) e l'origin. La firma lega in modo crittograficamente verificabile la risposta alla specifica challenge, impedendo attacchi di replay.

Richiesta del Client (Client → Server) Il client invia un oggetto `AuthenticatorAssertionResponse` contenente:

Campo	Descrizione
<code>id</code>	Credential ID (base64url)
<code>rawId</code>	Credential ID in binario (base64url)
<code>response.clientDataJSON</code>	JSON con tipo, challenge, origin (base64url)
<code>response.authenticatorData</code>	Struttura authenticatorData (base64url)
<code>response.signature</code>	Firma digitale del TPM (base64url)
<code>response.userHandle</code>	User handle opaco (base64url, opzionale)
<code>type</code>	Valore fisso "public-key"

Elaborazione Server-Side e Verifica Crittografica

1. Il server recupera la challenge associata al `session_id` e verifica che il tipo di cerimonia sia "authentication" e che la sessione non sia marcata come fittizia.
2. Carica le credenziali WebAuthn dell'utente e delega la verifica a `go-webauthn.FinishLogin`, che esegue:
 - (a) Verifica del tipo e dell'origin nel `clientDataJSON`;
 - (b) Verifica che la challenge nel `clientDataJSON` corrisponda a quella generata in fase *begin*;
 - (c) Verifica del `rpIdHash` nell'`authenticatorData`;
 - (d) **Verifica della firma**: ricalcola `SHA256(clientDataJSON)`, concatena con `authData` e verifica la firma σ usando la chiave pubblica memorizzata (registrata in fase di enrollment).
 - (e) **Controllo del signCount**: verifica che il contatore sia strettamente maggiore del valore registrato. Un contatore non crescente indica una possibile clonazione dell'autenticatore (**CloneWarning**), che causa il rifiuto immediato.
3. La credenziale verificata (con il nuovo `signCount`) è aggiornata nel database.
4. Viene avviata la fase di step-up OTP: generazione OTP, hashing HMAC-SHA256, invio email, persistenza della sessione OTP.

4.6.4 Emissione JWT

1. **Emissione del JWT RS256**: il server genera un token JWT firmato con la chiave privata RSA-2048 dell'IAM Service, con i seguenti claim:

Claim	Tipo	Descrizione
sub	string	User ID
role	string	Ruolo dell'utente
clearance_level	string	Livello di clearance
mfa_verified	bool	Sempre <code>true</code> dopo OTP
device_id	string	Credential ID TPM (se presente)
ja3	string	Fingerprint TLS JA3 (se presente)
iss	string	"iam-service.ztaleaks.local"
iat, nbf, exp	NumericDate	Emissione, validità, scadenza (15 min)
jti	string	Identificativo univoco del token (UUID)

2. **Aggiornamento del last_login_info:** in modo asincrono, il server aggiorna il record dell'utente con timestamp, IP e fingerprint JA3 dell'ultimo accesso.
3. **Eliminazione della sessione OTP:** il record temporaneo è cancellato.

4.7 Il servizio Business Logic

Il servizio Business Logic implementa le API REST dedicate alla gestione delle risorse della centrale. Sviluppato in Go, il servizio configura un logger JSON strutturato con il tag "business-logic" per ogni evento registrato e istanzia i repository MongoDB per ciascun dominio applicativo.

Il server configura le rotte applicative sfruttando le funzionalità introdotte in Go 1.22 per la definizione dei parametri di percorso all'interno del `ServeMux`.

Il middleware di logging `log_action` intercetta ogni transazione: estrae dall'header `X-Current-User` l'identità dell'utente autenticata e dall'header `X-Request-ID` il tracciante di correlazione, producendo una riga di log JSON strutturata con il nome dell'azione, il target, lo stato e l'eventuale errore.

Per garantire la protezione contro la manomissione diretta dei record nella base dati, ciascun repository applicativo implementa una convalida crittografica tramite la funzione `computeDataIntegrityHash`. All'atto dell'inserimento o della modifica di un documento, il repository calcola un hash SHA-256 concatenando i campi informativi del record separandoli con il carattere pipe. L'hash risultante viene memorizzato all'interno del campo `data_integrity_hash` dello stesso documento. Ad ogni successiva operazione di lettura, il repository ricalcola l'hash confrontandolo con quello memorizzato: un'eventuale divergenza blocca l'esposizione del record e restituisce un errore di violazione dell'integrità.

4.8 I database MongoDB

Il sistema impiega 2 istanze MongoDB separate per isolare le componenti di sicurezza dai dati applicativi della centrale.

Il Business DB gestisce i dati applicativi ed è configurato abilitando l'autenticazione interna delle connessioni. Lo script di configurazione crea 3 utenze con privilegi rigorosamente circoscritti: `personnel`, `manager` ed `admin`, ognuna delle quali ha privilegi di accesso in base alla collezione.

Il Security DB ha una configurazione finalizzata alla gestione degli accessi: memorizza le credenziali Argon2id degli utenti nella collezione `identity_users` (con campo `has_tpm` per il flag `WebAuthn` e struttura `last_login_info` con IP, timestamp e impronta JA3) e i dati dei dispositivi hardware accreditati nella collezione `device_fingerprints`, rimanendo inaccessibile a servizi esterni al piano di autenticazione e decisione.

4.9 Il seeder del Business DB

Il popolamento iniziale del Business DB è affidato a un'applicazione Go autonoma posizionata in `tools/seeder/`. L'applicazione si connette al database di produzione ed esegue l'inserimento dei record seguendo l'ordine imposto dalle dipendenze referenziali.

Il processo di inserimento avviene secondo la sequenza logica descritta nell'elenco seguente:

- inserimento delle zone fisiche della centrale;
- inserimento dei record del personale operante;
- associazione dei badge fisici di accesso e dei log di transito storico;
- popolamento dei parametri del reattore, degli ordini di manutenzione, dei documenti tecnici e dei materiali nucleari.

Ciascun inserimento verifica preventivamente la presenza di record per evitare duplicazioni, garantendo l'idempotenza del processo. L'applicazione calcola e popola gli hash crittografici di integrità per ciascun documento, rendendo la base dati sicura e verificabile fin dalla prima attivazione.

4.10 Il forwarder Splunk e l'osservabilità centralizzata

Il monitoraggio centralizzato si avvale di un'istanza Splunk Enterprise combinata con un Universal Forwarder (`splunk-uf`). La configurazione del forwarder è definita nel file `inputs.conf`, il quale monitora 10 directory di volume distinte contenenti i log in formato JSON strutturato prodotti da tutti i componenti dell'infrastruttura: il firewall nftables, le 3 istanze Snort (esterna, interna e intermedia), Envoy, il business-logic, MongoDB, l'identity service, il Security Orchestrator e OPA.

L'inoltro dei dati all'istanza Splunk avviene tramite la configurazione del file `outputs.conf` puntando alla porta standard del protocollo di indicizzazione. La correlazione end-to-end è realizzata propagando l'identificativo `X-Request-ID` generato da Envoy a tutti i componenti coinvolti: una singola ricerca in linguaggio SPL sul valore dell'identificatore consente di ricostruire la sequenza temporale di tutti gli eventi associati a una

determinata richiesta, attraversando i log di Envoy, del Security Orchestrator, dell'OPA e del servizio business applicativo.

Oltre ai log applicativi, ciascun container di database produce un audit trail a livello di base dati. Con il profiler MongoDB attivo (`textttoperationProfiling.mode=all`), un tailer interno al container (`profile-tailer`) emette, per ogni operazione sui dati, una riga JSON(campi `timestamp`, `service`, `utente_connesso`, `tipo_operazione`, `collezione`, `X-Current-User`). Ogni operazione è così attribuibile non solo al microservizio chiamante ma anche all'utente finale autenticato, completando il logging applicativo con un controllo incrociato a livello di persistenza.

5 Il modello Graphagate: Temporal Graph Network per la Zero Trust Architecture

5.1 Introduzione

Nel contesto di una Zero Trust Architecture (ZTA), il processo di autorizzazione continua richiede meccanismi dinamici per rilevare deviazioni dal comportamento abituale e segnali di compromissione. Il modello integrato con l'Orchestrator OPA è basato su una *Temporal Graph Network* (TGN), progettata specificamente per il *self-supervised anomaly detection* su stream di traffico continuo.

Ogni accesso (una richiesta IP/device verso una risorsa) rappresenta un arco temporale all'interno di un grafo in evoluzione. Il modello mantiene uno stato ricorrente per ciascuna entità (utente o risorsa) e analizza i vicini temporali recenti per assegnare uno score di anomalia in tempo reale, consentendo di bloccare le richieste ostili ed esfiltranti.

5.2 Il modello base: Temporal Graph Network (v3)

5.2.1 Architettura del sistema

L'architettura del modello combina la memoria ricorrente tipica dei TGN (Rossi et al., 2020) con un gestore del vicinato ottimizzato (bounded in RAM) e uno *scorer* a 2 teste che permette di analizzare le anomalie su 2 fronti: contestuale/policy e strutturale.

Componenti principali

- *TGNMemory*: struttura basata su GRU che aggiorna lo stato storico di ciascun nodo con i messaggi degli eventi in ingresso. La dimensione è impostata a 256 per gestire le impronte comportamentali.
- *Hashed Identity*: identità dei nodi mappate tramite funzioni di hash (`hash(URI) % hash_buckets`) per garantire totale *induttività* e scalabilità in presenza di entità mai viste prima.
- *MessageNeighborLoader*: buffer in RAM che memorizza gli ultimi vicini temporali di ciascun nodo (es. `neighbor_size=30`). Lavora con lookup in tempo $O(1)$ su matrici preallocate ed elimina la necessità di lenti database a grafo.

- *GraphAttentionEmbedding*: rete multi-hop con *TransformerConv* per calcolare l'embedding attendendo sui vicini storici, concatenando l'identità alla storia temporale.
- *Static Node Features*: vettore a 16 dimensioni associato a ciascun nodo, che codifica attributi ZTA essenziali come *device tier*, *clearance* e *trust score*, oltre a metriche estese introdotte nello schema v3 quali il *resource risk* (per innalzare la sensibilità su asset critici) e il *source internal/external flag* (per distinguere reti interne da esterne).
- *History Features*: per ogni arco valutato si calcolano 3 contatori causali e *benign-gated* (aggiornati solo su traffico approvato). A questi si aggiunge una seconda tripletta identica per le coppie *aux_src*→*dst* (es. per validare la *device habituality*), portando la dimensione a 6. Misurano quanto è abituale quell'accesso: una coppia mai vista da una sorgente attiva è la *novelty cue* (caratteristica di novità) del movimento laterale, che, combinata con la memoria temporale, porta il maggior contributo (ablation multi-seed a 3 seed: +0.163 AUC, il segnale dominante del laterale).

$$[\log(1+\text{pair_count}), \log(1+\text{src_count}), \text{pair_count}/(\text{src_count}+1)]$$

- *Dual Head Scorer*: lo score di un arco è la *somma* di 2 logit complementari, $\text{logit} = \text{feat_logit} + \text{struct_logit}$.
 - *Feature head* (*LinkPredictor*, MLP a 3 strati): consuma gli embedding dei 2 endpoint, il messaggio dell'evento, gli attributi statici con hashed-identity, le codifiche di recency (Δt coppia, Δt sorgente) e le *history features*. Cattura anomalie *contestuali* e di *policy* e veicola la *novelty cue* del laterale.
 - *Structural head*: similarità coseno (scalata da una temperatura apprendibile) delle proiezioni non-lineari degli embedding. È *marginale* sul laterale (ablation a 3 seed: +0.007 AUC), poiché su questo stream il segnale è già portato dalle *history features* e dalla memoria temporale; è comunque *mantenuta* come segnale complementare a basso costo (l'ottimizzatore le assegna una temperatura non banale, $\text{struct_scale} \approx 4.7$, dunque è attiva ma ridondante). Il suo contributo è plausibilmente sottostimato dal task sintetico - dove il laterale coincide quasi per costruzione con la *pair-novelty* già catturata dalle *history features* - e atteso più rilevante su topologie reali o in regime di *cold-start/poisoning* dei contatori, ma ciò resta *non verificato*.
- *Kill-chain Precursor* (prior di serving, non addestrato): il movimento laterale segue tipicamente un alert di recon (Snort / anomalia rilevata) sulla *stessa* entità, ma il gate predict-then-update scarta quel precursore dalla memoria TGN. Si mantiene quindi uno stato per-entità **recent_alert** e si applica un fattore *moltiplicativo* allo score, $1 + \max_boost \cdot 0.5^{\Delta t / \text{half_life}}$ (default $\max_boost=2$, $\text{half_life}=600\text{s}$). Moltiplicativo per costruzione: alza uno score già sospetto sopra soglia senza trasformare in falsi positivi gli score benigni ≈ 0 . Il suo contributo è però *marginale* (ablation multi-seed a 3 seed: +0.013 AUC), comparabile a quello della testa strutturale. Non

costituisce un input addestrato (il training solo-benigno lo renderebbe una feature morta).

5.2.2 Fase di addestramento e calibrazione

Il modello viene addestrato con un approccio *self-supervised* unicamente su traffico benigno, senza mai essere esposto a etichette di anomalia (unsupervised anomaly detection). Lo stream temporale sintetico generato viene suddiviso cronologicamente in 3 subset: addestramento (70%), validazione (10%) e test (20%).

L'obiettivo di apprendimento per la rete è il *link prediction*: il TGN è istruito per massimizzare lo score assegnato ad eventi realmente accaduti nella baseline benigna e minimizzare contemporaneamente lo score associato ad eventi artificialmente manipolati e generati a runtime (*negative sampling*).

Negative sampling e funzione di loss

L'ottimizzazione (AdamW) somma 3 termini self-supervised. Il dominante è una loss di ranking *InfoNCE* (allineata all'Average Precision): per ogni positivo benigno la sorgente è accoppiata a $K=5$ destinazioni *uniformemente casuali* e si impone che la dst-vera ottenga il logit più benigno *dato lo storico della sorgente*. In questo modo, la rete apprende $P(\text{dst} \mid \text{src}, \text{storia})$, assegnando score elevato agli accessi a bassa verosimiglianza (movimento laterale, violazioni di policy). La affiancano 2 ancoraggi BCE: un *positive anchor* che spinge i positivi benigni verso "benigno" fissandone la scala assoluta (l'InfoNCE fissa solo l'ordine relativo, e senza questo la soglia calibrata sull'FPR perderebbe significato), e dei *contextual negatives* che, sommando rumore gaussiano ($\sigma=0.5$) al messaggio dell'evento, addestrano la *Feature Head* a marcarlo anomalo; un meccanismo distinto dalla corruzione discreta usata in valutazione, così il modello non vede il test.

Calibrazione della soglia (cost-sensitive instradata sul segnale)

Il TGN non emette una classificazione netta ma uno score continuo confrontato con una soglia, calibrata via *replay* sul 10% di validazione held-out (lo split di test non è mai toccato in calibrazione). Poiché a serving la classe vera è ignota ma il *segnale di edge* (JA3/Snort/sensori) è osservabile, si calibrano e si instradano 2 soglie:

- *Soglia signal-dirty* (eventi il cui segnale già scatta), quantile al Target FPR dell'1% sugli score benigni. Questi eventi sono già intercettati dalla cheap rule baseline, quindi si mantiene la soglia conservativa.
- *Soglia signal-clean* (dove il laterale è indistinguibile dal benigno se non per il pattern temporale), soglia *cost-sensitive* che minimizza $\text{cost_ratio} \cdot \text{FN} + \text{FP}$ (default $\text{cost_ratio}=20$: un laterale mancato costa molto più di un falso allarme ri-sfidabile dall'orchestrator). Un *cap* esplicito sull'FPR del flusso clean ($\text{clean_fpr_cap}=0.05$) impedisce che la spinta sul recall faccia esplodere i falsi positivi. Necessario perché, pur con un'AUC laterale alta, il trade-off recall/FPR sul flusso clean resta ripido.

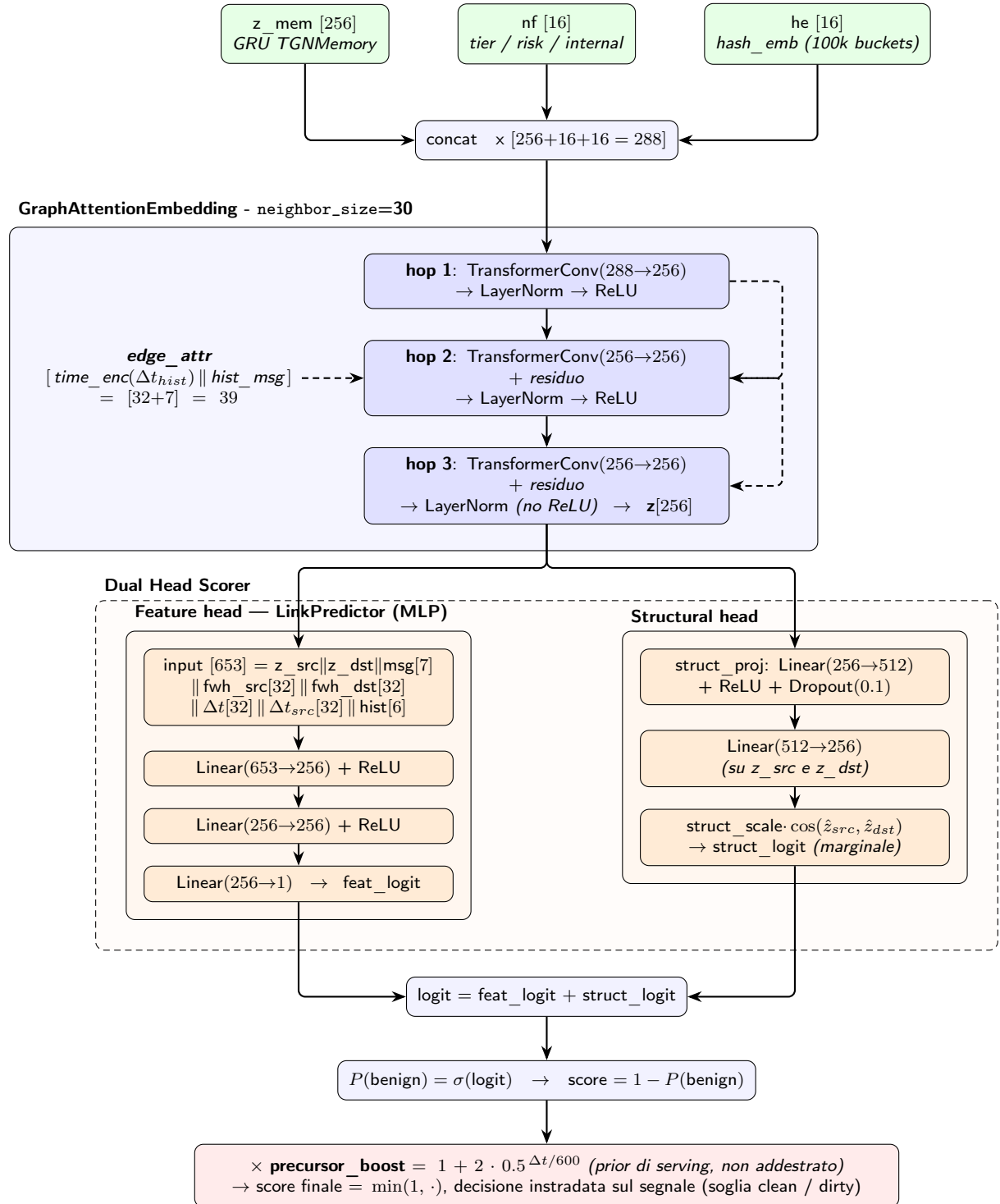


Figura 5.1: Schema dei layer del modello: i 3 hop di *GraphAttentionEmbedding* e le 2 teste (*Feature* e *Structural*) del *Dual Head Scorer*.

A inferenza la decisione è instradata per-evento: `signal_dirty` $\Rightarrow$ soglia dirty, altrimenti soglia clean (cost-sensitive). Entrambe le soglie sono persistite ed esposte da `serve_api` (anche su `/health`). OPA resta il decisore finale allow/deny.

5.2.3 Tipologie di anomalie rilevate in produzione

In fase di valutazione o in ambiente live, l'architettura rileva 3 macro-categorie di attacco, dimostrando vantaggi misurabili rispetto a baseline più semplici (rule-based, Isolation Forest, One-Class SVM e GNN non temporale; cfr. Sezione 5.2.4).

1. *Policy Anomaly*: l'entità agisce al di fuori del proprio ruolo, clearance o device tier. Intercettata agevolmente dalla Feature head grazie alle feature statiche ZTA.
2. *Contextual Anomaly*: la connessione ha caratteristiche insolite o ha innescato sensori IPS. Rilevata dalla Feature head decostruendo le *edge features*.
3. *Lateral Movement*: l'accesso è formalmente autorizzato a livello di regole OPA, ma *non abituale*. Avviene tipicamente nel "pivoting". Essendo indistinguibile sintatticamente dal traffico benigno, la classificazione ricade quasi del tutto sull'architettura implementata.

5.2.4 Valutazione sperimentale e confronto con le baseline

La valutazione è condotta sullo split di test (20% finale dello stream sintetico) tramite replay per-evento attraverso l'esatto codice di serving (`num_events`=200 000, di cui il 20% finale = 40 000 eventi di test), su **3 seed** [42, 7, 123] (media $\pm$ dev.std). Per quantificare il contributo *effettivo* della componente temporale, il TGN è confrontato con 3 baseline non supervisionate addestrate sullo *stesso* traffico benigno, con identico split cronologico, identici segnali tabellari (contatori di storia + prior precursore), soglia calibrata all'1% di FPR e protocollo di valutazione (codice in `tests/baselines/`); una quarta baseline *supervisionata* (XGBoost) è riportata solo come upper-bound di riferimento.

- *Isolation Forest*: modello non relazionale addestrato sulle sole feature statiche per-evento (nessuna struttura di grafo), privo di informazione strutturale (lateral AUC 0.645 ± 0.025).
- *One-Class SVM*: controparte kernel non relazionale dell'Isolation Forest (sole feature per-evento). Pur con AUC aggregata competitiva (0.801 ± 0.018), sul *lateral* resta a 0.599 ± 0.002 , confermando che il segnale temporale non è catturabile dalle sole feature statiche.
- *GNN non temporale*: ablation del TGN su grafo statico aggregato, con InfoNCE su destinazioni casuali più il rumore contestuale e le stesse *history features*, ma priva di memoria ricorrente e vicinato temporale (lateral AUC 0.451 ± 0.021 , $\approx$ caso).
- *XGBoost* (*supervisionato*, fuori categoria): addestrato su dataset etichettato (anch'esso generato artificialmente), raggiunge lateral AUC 0.929 ± 0.001 . Non è un

confronto equo col paradigma non supervisionato del TGN; è incluso solo per delimitare l'upper-bound raggiungibile avendo accesso alle label (assenti per costruzione nel nostro setting).

I risultati del confronto sono riportati nella Tabella 5.1.

Metrica (test set)	TGN	GNN non temp.	One-Class SVM	Isol. Forest
AUC aggregata	0.965 $\pm$ 0.007	0.555 $\pm$ 0.037	0.801 $\pm$ 0.018	0.763 $\pm$ 0.014
AP aggregata	0.922 $\pm$ 0.014	0.560 $\pm$ 0.021	0.739 $\pm$ 0.026	0.575 $\pm$ 0.016
Lateral — AUC	0.913 $\pm$ 0.014	0.451 $\pm$ 0.021	0.599 $\pm$ 0.002	0.645 $\pm$ 0.025
Lateral — Recall @1%FPR	0.166 $\pm$ 0.009	0.125 $\pm$ 0.006	0.062 $\pm$ 0.016	0.009 $\pm$ 0.002
Recall aggregata @1%FPR	0.665 $\pm$ 0.043	0.366 $\pm$ 0.004	0.479 $\pm$ 0.038	0.116 $\pm$ 0.020

Tabella 5.1: Confronto sul test set sintetico tra TGN e baseline non relazionali (3 seed [42,7,123], soglia globale all'1% FPR); il riferimento *supervisionato* XGBoost (upper-bound fuori categoria) non è incluso qui ed è discusso nel testo e nel quadro riepilogativo (Tab. 5.9).

Cost-sensitive routing

Per convertire la forte capacità di ranking del TGN (Tab. 5.1) in recall operativo, la decisione è instradata sul segnale con la soglia cost-sensitive calibrata in Sez. 5.2.2. Sul test sintetico (3 seed, media), raddoppia il recall laterale rispetto alla soglia globale all'1% FPR, al prezzo di un modesto aumento dell'FPR benigno; i valori per-classe e instradati sono riportati nella riga v3 di Tab. 5.3.

5.3 L'evoluzione: il nodo *Configuration* (schema v4)

5.3.1 Motivazione

Il modello descritto nella Sezione 5.2 (schema v3) modella ogni richiesta come una catena causale a 3 archi su 4 ruoli di nodo, *source* $\rightarrow$ *device* $\rightarrow$ *user* $\rightarrow$ *resource*. In quello schema il *fingerprint* TLS del client (JA3) è soltanto un *bit di validità* (`features[0]`): segnala se l'handshake è regolare, ma non è un'*identità*. Questo lascia scoperti 2 vettori d'attacco centrali nella ZTA:

- *Movimento laterale con tooling nuovo*: un dispositivo già noto, compromesso, inizia a parlare con un client/tool mai osservato su quella macchina. La validità TLS resta intatta (il tool usa una libreria regolare), ma il *fingerprint* è nuovo.
- *Furto di credenziali*: un attaccante che riusa le credenziali della vittima da un proprio client presenta un JA3 *diverso* da quello abituale dell'utente, pur con ruolo/clearance leciti (l'attaccante eredita i permessi della vittima).

Entrambi sono *signal-clean* e *policy-clean*: indistinguibili sintatticamente dal traffico benigno se non per l'*identità della configurazione*. Da qui la promozione della configurazione del client a quinto nodo.

5.3.2 Architettura del nodo *Configuration*

La configurazione è identificata da `conf:<ja3>` quando il *fingerprint* è disponibile, altrimenti dal generico `conf:guest` (sempre presente lato serving, default server-side). Il JA3 mantiene quindi un *doppio ruolo*, ortogonale: resta il bit di validità TLS in `features[0]` (catturato dalla *Feature head*) e diventa un'identità di nodo (catturata dalla memoria temporale e dalle *history features*). Per costruzione la dimensione del messaggio (`msg_dim=7`) e quella delle feature statiche di nodo (`node_feat_dim=16`) restano invariate: il nodo config, come i *source*, non porta attributi statici dedicati ma solo memoria ricorrente, hashed-identity e slot di trust. Lo schema dell'evento passa a `schema_version=4` (i checkpoint v1/v2/v3 sono rifiutati al caricamento).

Topologia: la catena causale a 5 archi

Il nodo config è *inserito tra source e device* nella catena causale, sostituendo l'arco diretto `source→device` con la coppia `source→config→device`, e aggiungendo un *binding* discriminante `config→user`. Il cammino più lungo è quindi:

$$source \rightarrow config \rightarrow device \rightarrow user \rightarrow resource.$$

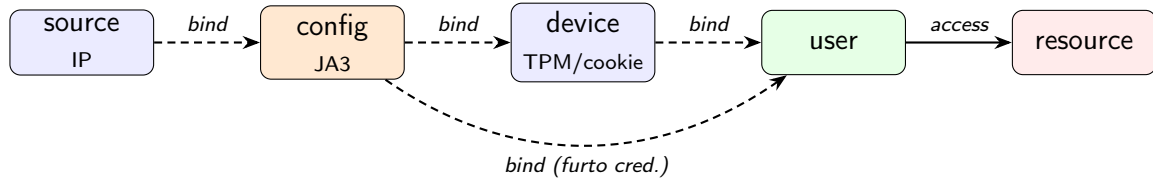


Figura 5.2: Catena causale dello schema v4, con il nodo *config* inserito tra *source* e *device* e il *binding* `config→user`; gli archi tratteggiati sono *binding* a messaggio-zero, il solo `access user→resource` porta il messaggio a 7 dimensioni.

Arco	Tipo	Stato
<code>user → resource</code>	access (msg 7-dim)	esistente
<code>device → user</code>	binding (msg-zero)	esistente
<code>source → config</code>	binding (msg-zero)	nuovo (v4)
<code>config → device</code>	binding (msg-zero)	nuovo (v4)
<code>config → user</code>	binding (msg-zero)	nuovo (v4)

Tabella 5.2: Edge set per richiesta nello schema v4 (config sempre presente lato serving), con l'ordine di commit in memoria identico in training/replay/serving.

L'architettura core (memoria ricorrente, *GraphAttentionEmbedding* multi-hop, *Dual Head Scorer*) è *invariata*: il modello è agnostico al numero di archi per evento, e i nuovi *binding* riusano la stessa primitiva di scoring degli archi esistenti (con *history features* senza ausiliario, come per *device*→*user*). Il generatore sintetico è esteso coerentemente: ogni macchina riceve 1–2 configurazioni abituali da un pool condiviso; il movimento laterale presenta con probabilità 0.5 un *tool* (config) mai usato da quel device; il furto di credenziali alloca al client attaccante un JA3 mai visto (`conf:atk-NNN`). Inoltre, per supportare rotte pubbliche (es. `/login`) che non richiedono un JWT e prevenire falsi positivi da cold-start, lo stream inietta regolarmente accessi a tali risorse usando lo slot utente `anonymous` combinato al fallback `dev:guest`, insegnando al modello la normalità del traffico non autenticato.

5.3.3 Risultati: il contributo del nodo config

La valutazione segue lo stesso protocollo della Sezione 5.2 (replay per-evento attraverso l'esatto codice di serving, split cronologico 70/10/20, soglia cost-sensitive instradata). Si riportano 2 confronti complementari: (i) il modello v3 vs v4 (*keying* per-cookie) all'*operating point* instradato (**3 seed** [42,7,123], media $\pm$ dev.std, 200 000 eventi / 15 epoche), e (ii) la *validazione mirata* del nodo config — un'ablazione controllata *a parità di dati* su seed multipli.

Confronto v3 → v4 (*keying* per-cookie)

La Tabella 5.3 confronta l'artefatto (*keying* per-cookie, coerente con la riga TGN della Tab. 5.1) prima e dopo l'introduzione del nodo config, al medesimo *operating point* (decisione cost-sensitive instradata sul segnale), su 3 seed. Il guadagno *robusto* è sul recall operativo del movimento laterale, che cresce oltre la banda di rumore multi-seed — coerentemente con la validazione *theft-rich* (Tab. 5.4) — mentre anche l'AUC laterale migliora in modo significativo; le metriche aggregate restano invece piatte entro il rumore. Il *trade-off*, leggibile in tabella, è un FPR benigno instradato più alto e un'AP aggregata lievemente inferiore: il nodo config non domina uniformemente, ma *sposta* l'*operating point* verso il laterale. È il comportamento atteso, poiché *config*→*device* cattura il “tool nuovo su device noto” e *config*→*user* il “client che quell'utente non usa abitualmente”, cioè i *tell* del laterale e del furto di credenziali.

Validazione mirata: il furto di credenziali

Per quantificare il contributo specifico del binding *config*→*user*, è stata eseguita una validazione mirata su uno stream *theft-rich* (slot e tasso d'incidente aumentati solo per questo test), confrontando — a parità di dati, su 3 **seed** (media $\pm$ dev.std) e con `save=False` (l'artefatto in *public/* non viene toccato) — il modello v4 completo contro la versione priva del nodo di configurazione (il modello ricade sul percorso legacy *source*→*device*, cioè $\approx$ v3 sugli stessi dati). I risultati sono in Tabella 5.4.

Metrica (test set)	v3 (4 nodi)	v4 (nodo config)	Δ
AUC aggregata	0.965 $\pm$ 0.007	0.964 $\pm$ 0.010	$\approx 0^\dagger$
AP aggregata	0.922 $\pm$ 0.014	0.897 $\pm$ 0.038	-0.025 †
Recall aggregata (intradata)	0.758 $\pm$ 0.030	0.829 $\pm$ 0.040	+0.071
Lateral — AUC	0.913 $\pm$ 0.014	0.930 $\pm$ 0.013	+0.017
Lateral — AP	0.522 $\pm$ 0.020	0.575 $\pm$ 0.098	+0.053 †
Lateral — Recall (intradata)	0.350 $\pm$ 0.034	0.577 $\pm$ 0.057	+0.227
Lateral — Recall (@1%FPR)	0.166 $\pm$ 0.009	0.363 $\pm$ 0.128	+0.197
Policy — AUC	0.987 $\pm$ 0.007	0.972 $\pm$ 0.015	-0.015
Contextual — AUC	0.994 $\pm$ 0.001	0.991 $\pm$ 0.002	-0.003
FPR benigno (intradato)	0.050 $\pm$ 0.002	0.066 $\pm$ 0.013	+0.016

Tabella 5.3: Confronto v3 vs v4 (*keying* per-cookie) sul medesimo test set sintetico, decisione cost-sensitive intradata (3 seed [42,7,123], media $\pm$ dev.std); † marca i Δ entro la banda di rumore multi-seed, quindi non significativi.

Metrica (test, theft-rich)	v4 (nodo config)	$\approx$ v3 (ablazione)	Δ
Furto credenziali — AUC	0.729 $\pm$ 0.088	0.676 $\pm$ 0.036	+0.053
Furto credenziali — Recall@thr	0.314 $\pm$ 0.107	0.206 $\pm$ 0.039	+0.108
Lateral — AUC	0.919 $\pm$ 0.018	0.913 $\pm$ 0.007	+0.006
Lateral — Recall@thr	0.469 $\pm$ 0.088	0.334 $\pm$ 0.014	+0.135
AUC aggregata	0.958 $\pm$ 0.011	0.956 $\pm$ 0.005	+0.002
Recall aggregata (intradata)	0.777 $\pm$ 0.047	0.744 $\pm$ 0.005	+0.033
FPR benigno (cookie-wipe)	0.060 $\pm$ 0.021	0.038 $\pm$ 0.033	+0.022

Tabella 5.4: Validazione mirata del nodo config su stream *theft-rich* (3 seed [42,7,123], `save=False`): il modello v4 completo contro la v3 a parità di dati (percorso legacy *source* $\rightarrow$ *device*, $\approx$ v3).

Sweep architetturale

L'introduzione di un quinto nodo suggerisce di verificare se al modello serva maggiore capacità espressiva. 3 direzioni — un layer nascosto aggiuntivo nell'MLP della *Feature head* (`link_pred_hidden_layers=3`), una memoria ricorrente più ampia (`memory_dim=384`) e più teste di attenzione (`gnn_heads=8`) — e la loro combinazione, valutate su 3 seed con `save=False`, *non* migliorano il movimento laterale rispetto alla baseline v4: il layer MLP aggiuntivo lascia l'AUC invariata ma abbassa il recall, mentre memoria e teste più ampie degradano nettamente le metriche e aumentano la varianza tra seed. Il segnale laterale è dunque *signal-bound*, non *capacity-bound*. Pertanto, l'architettura corrente è già adeguata e resta invariata.

Sintesi

Il nodo *configuration* (v4) alza sostanzialmente il **recall operativo** del movimento laterale e abilita la rilevazione del furto di credenziali (Sez. 5.3.3), senza costi architetturali: `msg_dim` e `node_feat_dim` restano invariati e lo sweep conferma che la capacità attuale è già adeguata. Come discusso sopra non è un dominio uniforme ma uno *spostamento dell'operating point* verso il laterale, al costo di un FPR benigno più alto. Questo guadagno operativo si *somma* a quello già documentato del TGN sulle baseline non-relazionali (Tab. 5.1), che non modellano la configurazione del client.

5.3.4 Esperimento: granularità dell'identità del dispositivo (nodo `dev:guest`)

Nello schema v4 ogni dispositivo senza TPM è un *nodo distinto*, identificato da un cookie persistente per-macchina (`ck:<id>`) con re-keying su un nodo “freddo” a ogni *cookie-wipe*. In analogia col fallback `conf:guest` (Sez. 5.3), si è valutato se convenga invece *collassare tutti i device non-TPM su un unico nodo condiviso* `dev:guest`: l'identità per-cookie aggiunge potere discriminante (un device mai visto è una novità) o è solo *rumore*, dato che laterale e furto credenziali sono *signal-clean* e portano il segnale sulle edge *config/source/user*? Il comportamento è esposto dal flag `guest_device_fallback` (default *on*, configurazione deployabile): quando attivo, ogni device non-TPM — *incluso quello dell'attaccante* nel furto di credenziali, anch'esso privo di TPM — collassa su `dev:guest` sia in addestramento (instradamento sul medesimo slot) sia a serving, e il *cookie-wipe* è *neutralizzato* (un nodo condiviso non ha un cookie per-macchina da resettare).

Il confronto *keying* per-cookie vs `dev:guest` è condotto su 2 stream, a parità di dati, 3 seed [42,7,123] ($\text{media} \pm \text{dev.std}$) e `save=False`: lo stream *theft-rich* della Sez. 5.3.3 (80k/12ep, slot 400/120, dove furto e wipe ricadono nel test split; Tab. 5.5) e lo stream *standard* (200k/15ep, il protocollo instradato di Tab. 5.3, confronto appaiato per seed; Tab. 5.6).

L'esito è *condizionato allo stream*. Sul **theft-rich** (Tab. 5.5) il collasso su `dev:guest` è un *miglioramento di Pareto*: non degrada il laterale ($\Delta \text{AUC} -0.004$, entro il rumore) e migliora nettamente il furto (AUC +0.103). L'identità per-cookie era infatti soprattutto *rumore* — i nodi-cookie sono sparsi e freddi, mentre il segnale d'attacco vive sulle *history features* di *user/config/source*, non sulla novità del device; concentrare il traffico non-TPM su un solo nodo dà *binding* più stabili (FPR benigno -0.008 , varianza tra seed molto più bassa) ed elimina l'intera classe di falsi positivi da *cookie-wipe* (n_{wiped} da 651 a 0). Sullo **stream standard** (Tab. 5.6), invece, il test split non contiene furto né wipe (Sez. 5.3.3): quei 2 vantaggi sono *assenti per costruzione* e affiora solo il costo, una *lieve regressione* sul laterale (AUC -0.030 , recall instradata -0.071) e sull'aggregato (AUC -0.014), con FPR piatto. Il guadagno del guest è dunque *condizionato* alla presenza di furto/wipe nello stream.

Sul piano del deployment il flag è lasciato *on* (`dev:guest` di default): in un contesto ZTA reale, dominato da furto di credenziali e dispositivi effimeri, il bilancio è favorevole, al

Metrica (test, theft-rich)	cookie (baseline)	dev:guest	Δ
Lateral — AUC	0.915 ± 0.019	0.911 ± 0.007	-0.004
Lateral — AP	0.583 ± 0.068	0.632 ± 0.017	$+0.049$
Lateral — Recall@thr	0.453 ± 0.060	0.488 ± 0.019	$+0.035$
Furto credenziali — AUC	0.701 ± 0.078	0.804 ± 0.024	$+0.103$
Furto credenziali — Recall@thr	0.244 ± 0.082	0.287 ± 0.062	$+0.043$
AUC aggregata	0.954 ± 0.013	0.961 ± 0.001	$+0.007$
Recall aggregata (instradata)	0.764 ± 0.036	0.787 ± 0.006	$+0.023$
FPR benigno (instradato)	0.045 ± 0.002	0.037 ± 0.004	-0.008
FPR cookie-wipe	0.041 ± 0.013 ($n=651$)	— ($n=0$)	neutralizzato

Tabella 5.5: Esperimento sull'identità del device: *keying* per-cookie vs collasso su **dev:guest** (3 seed [42,7,123], stream *theft-rich*, **save=False**); confronto distribuzionale, non appaiato evento-per-evento.

Metrica (test, stream standard)	cookie (baseline)	dev:guest (deployato)	Δ
AUC aggregata	0.979 ± 0.004	0.965 ± 0.005	-0.014
AP aggregata	0.955 ± 0.007	0.926 ± 0.021	-0.029
Recall aggregata (instradata)	0.851 ± 0.003	0.811 ± 0.000	-0.040
Lateral — AUC	0.952 ± 0.007	0.922 ± 0.009	-0.030
Lateral — AP	0.749 ± 0.027	0.652 ± 0.078	-0.097
Lateral — Recall (instradata)	0.603 ± 0.006	0.532 ± 0.028	-0.071
Lateral — Recall (@1%FPR)	0.458 ± 0.041	0.372 ± 0.065	-0.086
FPR benigno (instradato)	0.043 ± 0.008	0.042 ± 0.007	-0.001

Tabella 5.6: Identità del device sullo *stream standard* (200k/15ep, decisione instradata): *keying* per-cookie vs collasso su **dev:guest** (3 seed, **save=False**, confronto *appaiato* per seed). A differenza del regime theft-rich (Tab. 5.5), qui il guest è una *lieve regressione*: lo split di test standard non contiene furto né cookie-wipe.

prezzo di un costo che le metriche non catturano — la perdita dell'*attribuzione forense per-macchina*, recuperabile disattivando il flag. Le Tab. 5.3 e 5.1 restano valide come artefatto *per-cookie*, prodotto prima di questa adozione; il confronto onesto col guest è il Δ *appaiato* di Tab. 5.6, non i valori assoluti tra run con codice diverso (la lateral AUC per-cookie 0.952 vs lo 0.930 di Tab. 5.3 riflette miglorie di codice successive).

5.4 Deployment e specifiche hardware/software

Le primitive di model-serving (estrazione memoria ed espansione del grafo storico) operano asintoticamente a tempo costante $O(1)$, e il TGN mantiene tutto il suo stato dinamico e ricorrente nativamente in RAM. Da questa scelta discendono 2 conseguenze di deployment: il servizio è *single-worker* - lo stato comportamentale per-entità non è replicabile senza frammentarlo (limite discusso in Sez. 5.5) - ed è fondamentale il dimensionamento asincrono.

5.4.1 Piattaforma HW/SW (addestramento e inferenza)

Lo stesso container isolato ospita sia l'addestramento sia l'inferenza. Al fine di calcolare la backward-propagation e smaltire la mole della *Graph Attention*, esso si appoggia alle seguenti specifiche hardware/software:

- container engine nativo agganciato a librerie NVIDIA CUDA 13;
- hardware accelerato su GPU con architettura NVIDIA Blackwell (testato su RTX 5070 Ti). La GPU accelera la *Graph Attention* multi-hop in inferenza e la backward-propagation in addestramento; lo stato ricorrente della `TGNMemory` e i ring-buffer del `MessageNeighborLoader` sono mantenuti con accesso $O(1)$ su tensori preallocati.

Nel momento di chiusura del framework (o tramite specifici endpoint API persistenti), la memoria serializzata di PyTorch (`tgn_checkpoint.pt` e `tgn_stats.json`) viene salvata su disco per evitare cold-start e mantenere lo stato tra diverse esecuzioni del container.

5.4.2 Serving e latenza di inferenza

Il sistema finale eroga un'infrastruttura single-worker fondata su `FastAPI` (gestione I/O asincrono per polling concorrenziale) che elabora gli eventi con una latenza end-to-end (round-trip HTTP client→servizio sulla rete container, catena v4 completa a 5 archi *source→config→device→user→resource*) di $P50 \approx 9.6$ ms ($P99 \approx 10.8$ ms); l'omissione del binding di dispositivo non altera apprezzabilmente né la latenza né la detection in cold-start. Misure su GPU RTX 5070 Ti (VRAM occupata ~ 2.5 GB), tramite test client di streaming live in regime *cold-start* (entità mai viste prima, prefisso `prod_`): un sanity-check d'induttività più che un punto operativo, poiché in cold-start il modello opera ad alto recall ma bassa specificità (lateral recall $\sim 82\%$, specificità benigna $\sim 43\%$ — FPR gonfiato dall'assenza di storico).

5.4.3 Parametri di inferenza forniti dal Security Orchestrator

Il modello non è interrogato direttamente: è il Security Orchestrator a costruire, per ogni richiesta intercettata, l'evento da inviare al microservizio TGN. L'interazione avviene su 2 endpoint HTTP/JSON distinti, coerenti col gate anti-poisoning della Sez. 5.5:

- POST `/infer` — chiamata in *sola lettura* (`update=False`): restituisce lo score senza mutare la memoria del modello. L’orchestrator lo passa a OPA, che resta il decisore finale *allow/deny*.
- POST `/update` — invocata *solo* se OPA risponde *ALLOW*: *committa* l’evento avanzando lo stato della *TGNMemory* e le code dei vicini temporali. È questo il meccanismo che esclude dallo stato del modello il traffico classificato come ostile.

La risposta è il record `{anomaly_score, is_anomaly, threshold}`. In caso di endpoint non configurato o di errore di rete, il client adotta una politica *fail-suspicious*, restituendo uno score conservativo 0.99 con *confidence* bassa, così che la mancanza del segnale IA non si traduca in un permesso implicito.

Il corpo della richiesta è identico per i 2 endpoint ed è descritto nella Tabella 5.7. Le chiavi sono *namespaced* per tipo (`src:`, `conf:`, `tpm:`) così che, nel *NodeRegistry* condiviso del modello, un IP non possa mai aliasare uno slot di tipo diverso.

Campo JSON	Obbl.	Significato e costruzione (lato orchestrator)
<code>key_user</code>	sì	Chiave entità utente: lo <code>UserID</code> dei claim, oppure <code>anonymous</code> sulle rotte non autenticate (es. <code>/login</code>).
<code>key_device</code>	no	Chiave device <code>tpm:<id></code> , inviata <i>solo</i> se il TPM è attestato; altrimenti omessa (mai aliasing sull’IP).
<code>key_config</code>	no	Identità di configurazione <code>conf:<ja3></code> dal <i>fingerprint</i> JA3 (header o claim); se non risolvibile, il server adotta il generico <code>conf:guest</code> .
<code>key_source</code>	no	Contesto di rete sorgente <code>src:<ip></code> del client.
<code>key_dst</code>	sì	URI della risorsa, normalizzato per collassare le sottorotte parametriche su una base; deve combaciare con i <code>RESOURCE_URIS</code> usati in addestramento.
<code>timestamp</code>	sì	Istante dell’evento (epoch Unix, intero).
<code>features</code>	sì	Messaggio dell’arco <i>access user→resource</i> : vettore a 7 dimensioni (<code>msg_dim</code>), dettagliato in Tab. 5.8.
<code>user_feat</code>	no	Feature statiche del nodo utente: vettore a 16 dim (<code>node_feat_dim</code>), <i>interamente nullo</i> (contratto di training: ruolo e clearance viaggiano nel messaggio).
<code>device_feat</code>	no	Feature statiche del nodo device: vettore a 16 dim con il solo <code>node_feat[2] = tier</code> (1.0 TPM+cert, 0.5 cert senza TPM, 0.0 nessuno).
<code>dst_feat</code>	no	Feature statiche della risorsa: <i>non inviato</i> (il <i>resource risk</i> è già codificato nel checkpoint addestrato).

Tabella 5.7: Campi del payload JSON inviato dal Security Orchestrator al microservizio TGN (endpoint `/infer` e `/update`).

Il campo `features` è il cuore informativo dell’evento: codifica i segnali Zero-Trust osservabili sull’arco di accesso, nell’ordine fisso riportato nella Tabella 5.8. I primi 4 elementi sono bit di segnale (validità TLS e alert IPS); gli ultimi 3 sono attributi della richiesta: il metodo HTTP (0–4) e ruolo/clearance normalizzati in $[0, 1]$.

Idx	Nome	Valori	Significato
0	ja3Float	{0,1}	Bit di validità TLS: 1 se il JA3 osservato coincide con quello atteso dai claim, 0 in caso di discordanza.
1	alertEdge	{0,1}	1 se un alert Snort di <i>edge</i> (perimetro) è attivo per l'IP client o envoy.
2	alertMid	{0,1}	1 se è attivo un alert Snort <i>mid</i> (intermedio).
3	alertInt	{0,1}	1 se è attivo un alert Snort <i>internal</i> (interno).
4	methodFloat	0-4	Metodo HTTP: GET= 0, POST= 1, PUT= 2, DELETE= 3, PATCH= 4.
5	roleVal	[0,1]	Ruolo normalizzato: indice in [guest, operator, manager, admin] diviso per 3.
6	clrVal	[0,1]	Clearance normalizzata: indice in [PUBLIC, INTERNAL, CONFIDENTIAL, SECRET, TOP_SECRET] diviso per 4.

Tabella 5.8: Composizione del vettore **features** a 7 dimensioni (**msg_dim**=7), nell'ordine esatto con cui l'orchestrator lo costruisce.

Il microservizio rifiuta con HTTP 422 ogni payload le cui dimensioni non corrispondano al modello addestrato: **features** deve avere lunghezza esattamente 7 e i vettori di nodo, se presenti, lunghezza 16. Il modello impone inoltre **schema_version**=4: i checkpoint delle versioni precedenti (v1/v2/v3) sono respinti al caricamento.

A titolo di esempio, la richiesta seguente rappresenta un utente *operator* con clearance *CONFIDENTIAL* (**roleVal**= 1/3, **clrVal**= 0.5) che accede in *GET* (**methodFloat**= 0) da un dispositivo attestato via TPM (**device_feat**[2]= 1.0), con JA3 coerente (**ja3Float**= 1.0) e nessun alert IPS attivo:

```
POST /infer
{
  "key_user":    "u-1042",
  "key_device":  "tpm:dev-1042",
  "key_config":  "conf:769,47-53-5,0-23-65281,29-23-24,0",
  "key_source":  "src:10.0.3.14",
  "key_dst":     "/reactor/telemetry",
  "timestamp":   1750768800,
  "features":    [1.0, 0.0, 0.0, 0.0, 0.0, 0.3333, 0.5],
  "user_feat":   [0,0,0,0,0,0,0,0,0,0,0,0,0,0,0,0],
  "device_feat": [0,0,1.0,0,0,0,0,0,0,0,0,0,0,0,0,0]
}
```

5.5 Limiti del modello

5.5.1 Assenza di scalabilità orizzontale

Il limite di deployment più strutturale discende direttamente dal design illustrato in Sez. 5.4: lo stato comportamentale per-entità - la memoria ricorrente della `TGNMemory`, i ring-buffer dei vicini temporali del `MessageNeighborLoader` e i contatori espliciti di *history* - risiede interamente in RAM all'interno di un *singolo worker*. Replicare il servizio orizzontalmente (più repliche dietro un *load balancer*) frammenterebbe questo database comportamentale: ogni replica osserverebbe soltanto una frazione dello stream e accumulerebbe una memoria e dei contatori *parziali e incoerenti*, degradando proprio il segnale temporale su cui poggia la rilevazione del movimento laterale. Non esiste inoltre uno stato condiviso a bassa latenza consultabile in tempo $O(1)$ a ogni evento senza reintrodurre quel database a grafo che l'architettura ha esplicitamente eliminato. La scalabilità del sistema è quindi *verticale* (GPU e RAM più capienti, per sostenere grafi e memorie più ampi) e *asincrona* (l'I/O non bloccante di `FastAPI` assorbe il carico concorrenziale su un singolo processo), non orizzontale. Una distribuzione del traffico tra repliche richiederebbe uno *sharding* coerente per-entità (ogni entità sempre instradata alla medesima replica), con la complessità e i punti di fallimento che ciò comporta; quest'ultima rappresenta, assieme a DB a grafo ad elevate prestazioni, una direzione di lavoro futura non supportata dall'artefatto corrente.

5.5.2 La sfida del lateral movement

Senza l'ausilio delle etichette (unsupervised), il lateral movement non mostra tracce o indicatori evidenti: è identico (a livello di feature) a un accesso benigno non abituale. Le leve che lo rendono *ordinabile* (lateral AUC 0.913 ± 0.014 , contro ~ 0.45 della GNN statica) sono il vicinato temporale ampio e soprattutto le *history features* esplicite, come quantificato dall'ablation multi-seed in Sez. 5.2; la conversione del ranking in recall operativo passa poi per la soglia cost-sensitive instradata (Sez. 5.2.2, risultati in Sez. 5.2.4). Resta comunque la classe più ostica (AP ~ 0.52), pur nettamente sopra le baseline (cfr. Sez. 5.2.4).

5.5.3 Anti-poisoning gate nel live stream

Il design offline del testing replica 1:1 il routing live, prevenendo fenomeni di *data leakage*. Tuttavia, l'ambiente di deployment espone alla minaccia di *data poisoning*. Un aggressore persistente potrebbe infiltrarsi immettendo attacchi lenti per abituare il grafo ai propri comportamenti nocivi, sfalsando lentamente lo scoring e la similarità del coseno. Il problema è mitigato dal gate anti-avvelenamento: sia l'internal state della `TGNMemory` che le code a scorrimento dei vicini temporali vengono aggiornate e *committate* in RAM solo nel caso in cui lo score della rete si posizioni sotto il limite calcolato per le minacce ($< threshold$). I pacchetti classificati come anomalia, inviati a OPA, vengono ignorati dal sistema di Intelligenza Artificiale, preservando l'integrità dello stato vettoriale del modello.

5.6 Quadro riepilogativo: confronto di tutti i modelli

La Tabella 5.9 consolida le prestazioni dei modelli in un unico quadro, organizzato in 3 pannelli *per protocollo*: **sono validi solo i confronti all'interno dello stesso pannello**. Lo scopo è dare una lettura d'insieme della progressione — dalle baseline non relazionali al TGN, e dal modello a 4 nodi (v3) a quello con nodo *configuration* (v4) — senza dover ricomporre i numeri sparsi nelle Tabelle 5.1, 5.3, 5.4 e 5.5.

Modello / variante	AUC agg	AP agg	Lat. AUC	Lat. AP	Lat. Recall	agg Recall
<i>Pannello A — stream standard, 3 seed [42,7,123] (media, 200k ev.), soglia globale 1% FPR</i>						
TGN (v3, per-cookie)	0.965	0.922	0.913	—	0.166	0.665
GNN non temporale (ablation)	0.555	0.560	0.451	—	0.125 [†]	0.366
One-Class SVM	0.801	0.739	0.599	—	0.062	0.479
Isolation Forest	0.763	0.575	0.645	—	0.009	0.116
XGBoost (supervisionato) [‡]	0.974	0.948	0.929	—	0.339	0.772
<i>Pannello B — stream standard, 3 seed [42,7,123] (media), decisione cost-sensitive instradata</i>						
v3 (4 nodi, per-cookie)	0.965	0.922	0.913	0.522	0.350	0.758
v4 (nodo config, per-cookie)	0.964	0.897	0.930	0.575	0.577	0.829
v4 + dev:guest (deployato)*	0.965	0.926	0.922	0.652	0.532	0.811
<i>Pannello C — stream theft-rich, 3 seed (media), ablazioni controllate (save=False)</i>						
v4 (nodo config)	0.958	—	0.919	—	0.469	0.777
≈v3 (ablazione config)	0.956	—	0.913	—	0.334	0.744
v4 + dev:guest	0.961	—	0.911	0.632	0.488	0.787

Tabella 5.9: Quadro riepilogativo di tutti i modelli e varianti: **sono validi solo i confronti intra-pannello** (protocolli diversi). *Lat. Recall* e *agg Recall* sono a soglia globale 1% FPR nel Pannello A e a decisione instradata nei Pannelli B/C. [†] recall spurio (GNN, AUC≈caso); [‡] XGBoost *supervisionato* (upper-bound fuori categoria). * riga dev:guest (modello deployato) da un run appaiato successivo con codice aggiornato: i suoi valori *assoluti* non sono direttamente confrontabili con le righe v3/v4 soprastanti (prodotte prima di alcune migliorie); il confronto valido col per-cookie è il Δ *appaiato* di Tab. 5.6 (−0.030 lat AUC), non la differenza con questa tabella.

6 Validazione e Test del Sistema

Il presente capitolo espone i risultati delle procedure di validazione effettuate sull'architettura sviluppata, articolandosi in due ambiti di analisi principali: i test prestazionali e i test di sicurezza.

6.1 Test Prestazionali e di Carico (Postman)

In questa sezione vengono presentati i risultati dei test di carico e affidabilità condotti sulle API dell'applicazione sviluppata. L'obiettivo dell'analisi è verificare la resilienza, i tempi di risposta e la stabilità del backend simulando diversi scenari di accesso concorrente, al fine di individuare potenziali colli di bottiglia o vulnerabilità legate alla disponibilità del servizio (es. mitigazione di attacchi di tipo *Denial of Service* elementari o problemi di gestione delle risorse).

6.1.1 Ambiente di Test e Premessa Metodologica

I test sono stati eseguiti all'interno di un ambiente controllato in locale (*localhost*). Per garantire la replicabilità dei risultati, si riportano di seguito le specifiche hardware delle macchine ospitanti su cui sono stati eseguiti sia l'applicazione sia l'istanza dello strumento di testing:

- **PC portatile:** CPU: AMD Ryzen 7 4000, **Memoria RAM:** 16 GB DDR4, **GPU:** Non dedicata
- **PC fisso:** CPU: AMD Ryzen 9 9900X (12c, 24t), **Memoria RAM:** 32 GB DDR5, **GPU:** NVIDIA 5070Ti (16 GB VRAM)
- **Strumento di Testing:** Postman

Nota di contesto: L'assenza di una GPU dedicata sul PC portatile influisce sulle prestazioni metriche dell'applicazione, in quanto il carico di lavoro del modello di IA è interamente gravato sulla CPU e sulla memoria RAM.

6.1.2 Analisi dei Risultati e Scenari di Carico

I test effettuati hanno simulato diverse curve di carico misurate in *Virtual Users* (VU). Di seguito vengono analizzati nel dettaglio i singoli scenari eseguiti.

PC portatile

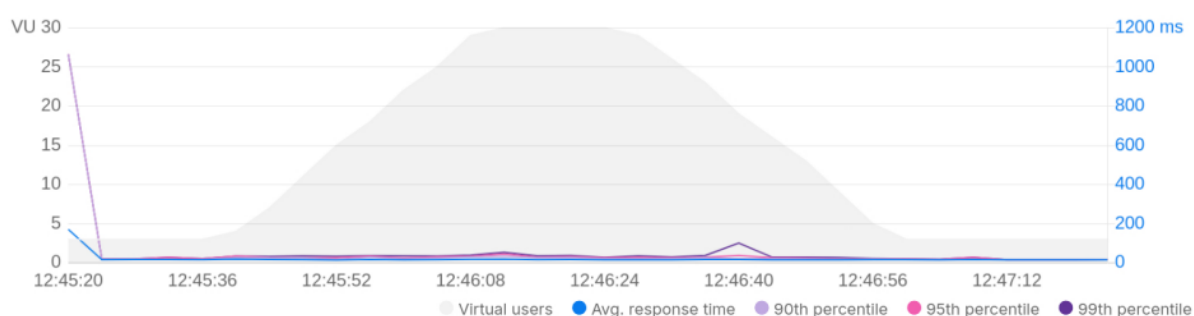
Tabella 6.1: Metriche delle prestazioni registrate su Postman (PC portatile)

Scenario di Test	Profilo di Carico	Tempo Medio (Avg)	Tempo Max	Durata
Carico Costante	5 VU costanti	~950 ms	1.6 s	3 min
Rampa Lineare	Da 1 a 5 VU	~1.0 s (a regime)	–	Var.
Picco Repentino	Spike 5 VU	–	1.0 s	Impuls.
Picco Repentino	Spike 10 VU	–	2.0 s	Impuls.
Rampa Incrementale	Da 1 a 10 VU	~1.5 s (a regime)	–	Var.

PC fisso

Tabella 6.2: Metriche delle prestazioni registrate su Postman (PC fisso)

Scenario di Test	Profilo di Carico	Tempo Medio (Avg)	Tempo Max	Durata
Carico Costante	5 VU costanti	~21 ms	1 s	2 min
Rampa Lineare	Da 1 a 5 VU	~17 ms a regime	–	2 min
Carico Costante	20 VU costanti	~32 ms	1.6 s	2 min
Rampa Lineare	Da 1 a 20 VU	~16 ms a regime	–	Var.
Picco Repentino	Spike 20 VU	–	4.0 s	Impuls.
Rampa Lineare	Da 1 a 30 VU	~18 ms a regime	–	Var.
Rampa Lineare up&down	30 VU	18 ms (40 ms a regime)	1.65 s	–
Picco Repentino	Spike 30 VU	–	7.0 s	Impuls.
Rampa Lineare up&down	100 VU	268 ms (500 ms a regime)	3 s	2 min

**Figura 6.1:** Grafico Peak 30 VU

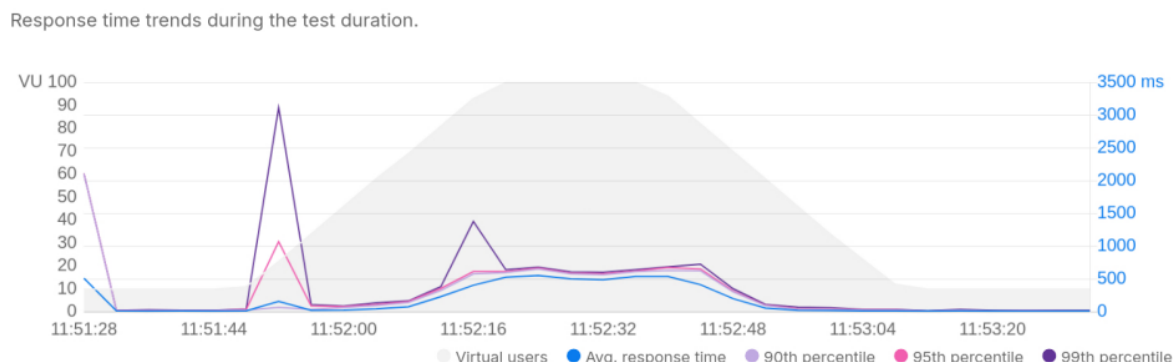


Figura 6.2: Grafico Peak 100 VU

Considerazioni Tecniche

L'esecuzione dei test di carico a volumi di traffico reali ha permesso di delineare con maggiore precisione i limiti di scalabilità e la robustezza del backend sviluppato. L'analisi dei dati aggregati nelle tabelle 6.1 e 6.2 evidenzia i seguenti comportamenti del sistema:

- **Efficienza in Condizioni Standard (Saturazione Bassa/Media):** Nello scenario a carico costante con 5 VU, il sistema risponde con un tempo medio estremamente ridotto (~ 21 ms). Questo valore, unito ai ~ 32 ms registrati con 20 VU costanti, dimostra l'ottima efficienza della logica di routing e della gestione dei thread.
- **Scalabilità Lineare e Curve di Ramp-up:** I test di *Ramp-up* lineare (fino a 5, 20 e 30 VU) mostrano un comportamento quasi ottimale, con tempi a regime stabili tra i 16 ms e i 18 ms. Il server si dimostra capace di allocare dinamicamente le risorse necessarie man mano che nuove connessioni vengono stabilite, senza subire degradazioni prestazionali premature.
- **Analisi degli Scenari di Stress Avanzati (30 e 100 VU):** Nel test *Ramp-up up&down* a 30 VU si nota un primo incremento del tempo a regime, che sale a 40 ms. La vera e propria soglia di stress strutturale viene tuttavia raggiunta nello scenario a 100 VU (*Ramp-up up&down*): in questo caso il tempo medio globale si attesta a 268 ms, ma subisce un raddoppio sensibile arrivando a 500 ms una volta raggiunto il pieno regime di carico.
- **Resistenza agli Spike:** Lo *Spike* a 20 VU mostra un tempo massimo di 4.0 s, che sale linearmente a 7.0 s nello *Spike* a 30 VU; anche nel *Peak* a 100 VU in fase di salita è presente un tempo massimo di risposta di 3.0 s. Questo incremento dei tempi di risposta massimi durante i picchi impulsivi evidenzia che il backend, pur non andando in *crash*, soffre di un fenomeno temporaneo di *saturazione delle risorse* quando riceve un numero anomalo di richieste improvvise, situazione che viene comunque assorbita superata la fase critica.

6.2 Test di Sicurezza e Modello Zero Trust

A completamento dell'analisi prestazionale, è stata condotta una batteria di test di sicurezza (eseguiti tramite una suite di test integrata nel cluster Docker) volti a verificare l'effettiva capacità dell'architettura Zero Trust di intercettare, valutare e neutralizzare pattern di attacco noti e comportamenti anomali.

I test eseguiti hanno simulato sia attacchi frontali diretti contro il proxy esposto (Envoy), sia tentativi furtivi di movimento laterale diretti ai servizi interni, validando il funzionamento combinato del sistema di Intrusion Detection (Snort) e del decisore intelligente (AI Scorer).

6.2.1 Scenari di Attacco Simulati

La suite di test automatizzata ha replicato i seguenti scenari malevoli:

- **SQL Injection (Mid-Level).** Simulazione di una query malevola all'endpoint delle API (`UNION SELECT * FROM users`), correttamente rilevata dalle regole Snort intermedie e bloccata (restituendo un errore 403 Forbidden).
- **Cross-Site Scripting (XSS).** Iniezione di uno script dannoso all'interno dei parametri di richiesta HTTP, parimenti neutralizzata dalla pipeline di sicurezza.
- **Utilizzo di Protocolli Obsoleti (Legacy TLS).** Invio di richieste di handshake SSLv3 forzate, le quali violano le policy di crittografia aggiornate e scatenano allarmi specifici a livello di rete.
- **Movimento Laterale Furtivo (Slowloris).** Per testare la resilienza alle minacce interne, il client ha bypassato volontariamente il proxy tentando una connessione diretta all'interfaccia dell'Orchestrator. Per eludere le rigide soglie volumetriche, l'attacco è stato condotto con la tecnica *Slowloris*, trasmettendo un frammento di intestazione HTTP ogni due secondi, consumando le risorse senza destare allarmi di rete elementari.

6.2.2 L'Intervento dell'AI Scorer

Il banco di prova si è concluso con la verifica sul motore di intelligenza artificiale. A tale scopo è stata inviata una richiesta HTTP legittima (indirizzata a `/login`) e dotata di certificati crittografici validi, per innescare il flusso autorizzativo standard di Envoy verso l'Orchestrator.

Nonostante la richiesta risultasse formalmente valida, il sistema ha dimostrato un comportamento adattivo: l'AI Scorer ha analizzato la cronologia recente del client, che includeva i tentativi di attacco precedentemente simulati (tra cui il movimento laterale). Rilevando tali pattern anomali, il modello ha incrementato lo score di anomalia associato al client. Poiché il livello di rischio risultante ha superato le tolleranze consentite dalle policy in OPA, la richiesta è stata respinta preventivamente (HTTP 403 Forbidden).

Questi risultati confermano empiricamente che il sistema garantisce una validazione continua del comportamento, mitigando le minacce provenienti da entità compromesse prima che queste possano accedere alle risorse critiche dell'infrastruttura.

7 Conclusioni e sviluppi futuri

Il progetto ZTALeaks ha esplorato l'applicazione dei principi del modello Zero Trust (NIST SP 800-207) attraverso la progettazione e l'implementazione di un'architettura di riferimento containerizzata. L'adozione del caso d'uso di una centrale nucleare, caratterizzato da severi requisiti di confidenzialità e ruoli operativi ben definiti, ha permesso di validare le scelte architetturali e i meccanismi di controllo degli accessi in uno scenario ad alto rischio, distribuendo le responsabilità di sicurezza tra i vari componenti del sistema.

7.1 Risultati ottenuti

Dal punto di vista architetturale, l'implementazione ha mantenuto una separazione rigorosa tra Policy Enforcement Point (Envoy Proxy) e Policy Decision Point (Security Orchestrator, OPA e modello AI). Questa suddivisione, unita a una topologia di rete articolata in segmenti Docker isolati (Front-Net, Auth-Net, Back-Net e Snort-Net), ha consentito di applicare il principio della *complete mediation* a livello di rete, vincolando il traffico ai soli percorsi autorizzati.

Il controllo degli accessi è stato strutturato su tre livelli complementari: un livello Role-Based Access Control (RBAC), per mappare i ruoli aziendali estratti dai token JWT in etichette di sicurezza; un livello Attribute-Based Access Control (ABAC), per la valutazione contestuale delle richieste (percorso, metodo HTTP, dispositivo e score di rischio dinamico); e un'implementazione del modello Bell-LaPadula tramite policy Rego in OPA, per imporre formalmente la *Simple Security Property* e la *Star Property*, includendo il meccanismo del *Trusted Subject* per la declassificazione controllata.

L'introduzione di un algoritmo di fiducia ibrido ha permesso di estendere i controlli statici con una valutazione continua del rischio fornita dal modello Graphagate. Le decisioni di accesso vengono prese ponderando il beneficio dell'operazione con lo score di anomalia contestuale, richiedendo che il beneficio netto superi una soglia predefinita per ciascun endpoint. Tale approccio si è dimostrato efficace nel mitigare potenziali attacchi condotti con credenziali valide ma associati a pattern comportamentali anomali.

Per quanto riguarda la rilevazione delle minacce, il modello Temporal Graph Network (Graphagate) ha ottenuto una AUC aggregata di 0.965 ± 0.007 e una recall aggregata pari a 0.811 sul set di test sintetico, e una AUC specifica sul movimento laterale pari a 0.922, dimostrando prestazioni di rilievo rispetto alle baseline non relazionali testate. L'evoluzione dello schema dati alla versione v4, con l'introduzione del nodo *Configuration*, ha migliorato la capacità di rilevazione del movimento laterale e permesso l'identificazione di simulazioni di furto di credenziali. È stato inoltre validato il meccanismo anti-poisoning, che previene l'inquinamento del modello condizionando l'aggiornamento dello stato comportamentale all'esito positivo delle valutazioni in OPA.

L'infrastruttura di osservabilità, basata sulla propagazione dell'**X-Request-ID** e sulla centralizzazione dei log in Splunk, ha garantito una tracciabilità completa delle richieste attraverso firewall, proxy, orchestratore e servizi di backend, integrata da un audit a livello di base dati che registra ogni operazione MongoDB associandola al microservizio e all'utente finale responsabili. I test di carico hanno evidenziato tempi di risposta medi tra i 16 e i 32 ms per carichi fino a 20 utenti concorrenti, con una latenza del modello TGN adeguata per il percorso decisionale sincrono ($P50 \approx 9.6$ ms). Le simulazioni di attacco hanno infine confermato la capacità della pipeline di rilevare e bloccare varie tipologie di minacce, tra cui SQL injection, XSS, connessioni TLS non sicure, attacchi Slowloris e movimenti laterali.

7.2 Limiti e sviluppi futuri

L'architettura proposta, pur dimostrando l'applicabilità dei principi Zero Trust nel contesto in esame, presenta alcuni limiti architetturali e operativi che delineano diverse aree di miglioramento per lavori futuri.

Un primo limite riguarda la gestione dei certificati: la configurazione attuale di Envoy (`require_client_certificate: false`) negozia il trasporto TLS in modo permissivo, demandando l'autenticazione del client allo strato applicativo. Inoltre, l'assenza di un meccanismo di revoca (come CRL o OCSP) rappresenta una vulnerabilità in scenari ad alto rischio. Come sviluppo futuro, si prevede l'adozione di certificati a vita breve emessi da una Certificate Authority interna automatizzata, un approccio che ridurrebbe l'esposizione ai rischi di compromissione senza introdurre il carico infrastrutturale dei sistemi di revoca tradizionali.

Sul fronte dell'autenticazione, l'attuale meccanismo a due fattori (basato su OTP via email) risulta statico e potenzialmente debole. Una sua naturale evoluzione è l'implementazione dell'autenticazione adattiva: richiedere il secondo fattore in modo selettivo, sulla base dello score di rischio in tempo reale valutato dall'orchestratore, migliorerebbe la postura di sicurezza preservando l'accettabilità psicologica del sistema per gli utenti a basso rischio.

Per quanto concerne il controllo degli accessi, l'attuale implementazione del modello Bell-LaPadula non copre la *Discretionary Security Property* (DSP). La sua integrazione permetterebbe un controllo più granulare, sovrapponendo una matrice degli accessi discrezionale ai vincoli mandatori.

L'impiego del modello di machine learning presenta un vincolo di scalabilità orizzontale: lo stato comportamentale risiede nella RAM del singolo worker, rendendo complessa la replicazione senza degradare la coerenza del segnale temporale. Un possibile sviluppo futuro prevede l'introduzione di tecniche di sharding coerente per entità; oppure si potrebbe utilizzare un database a grafo ad elevate prestazioni, così da permettere di avere più istanze di modello che condividono però la stessa memoria. Inoltre, per il consolidamento del modello, risulterebbe fondamentale validarne le prestazioni su dataset di

traffico di rete reale, al fine di verificare le metriche di classificazione in ambienti operativi non controllati.

A livello infrastrutturale, la transizione dall'attuale orchestrazione basata su Docker Compose verso un cluster Kubernetes (per il quale sono state già approntate configurazioni preliminari) conferirebbe maggiore resilienza, auto-healing e scalabilità al sistema. In tale contesto, l'introduzione di un service mesh come Istio permetterebbe di estendere in modo nativo le garanzie del *mutual TLS* alle comunicazioni interne tra i microservizi.

Dal punto di vista dell'osservabilità, il sistema beneficerebbe dell'adozione dello standard OpenTelemetry. Questo permetterebbe di superare l'attuale approccio basato puramente sui log, consentendo la correlazione nativa tra metriche prestazionali, tracce distribuite ed eventi di sicurezza all'interno di dashboard unificate, facilitando così il monitoraggio e le procedure di *incident response*.

In conclusione, il progetto ZTALeaks offre un prototipo funzionale che integra modelli formali di controllo degli accessi, analisi comportamentale basata su Intelligenza Artificiale e tecniche di sicurezza infrastrutturale. Questo elaborato dimostra la fattibilità di un'architettura Zero Trust coerente e tracciabile per la protezione di un dominio critico, fornendo allo stesso tempo una base solida e verificabile per successive evoluzioni e applicazioni nel settore della sicurezza informatica.

Bibliografia

- [1] Scott Rose, Oliver Borchert, Stu Mitchell, Sean Connelly. *Zero Trust Architecture*. NIST Special Publication 800-207, National Institute of Standards and Technology, Agosto 2020. <https://doi.org/10.6028/NIST.SP.800-207>
- [2] Emanuele Rossi, Ben Chamberlain, Fabrizio Frasca, Davide Eynard, Federico Monti, Michael Bronstein. *Temporal Graph Networks for Deep Learning on Dynamic Graphs*. In Proceedings of the ICML 2020 Workshop on Graph Representation Learning, 2020. <https://arxiv.org/abs/2006.10637>
- [3] *PyTorch: An Imperative Style, High-Performance Deep Learning Library*. In Advances in Neural Information Processing Systems 32 (NeurIPS), 2019. <https://pytorch.org/>
- [4] The Go Authors. *The Go Programming Language Documentation*. <https://go.dev/doc/>
- [5] Ultralytics. *Ultralytics Repository*. <https://www.ultralytics.com/it/glossary/graph-neural-network-gnn>
- [6] E. Rescorla. *The Transport Layer Security (TLS) Protocol Version 1.3*. RFC 8446, IETF, Agosto 2018. <https://datatracker.ietf.org/doc/html/rfc8446>
- [7] Jerome H. Saltzer, Michael D. Schroeder. *The Protection of Information in Computer Systems*. Proceedings of the IEEE, vol. 63, no. 9, pp. 1278-1308, Settembre 1975. <https://doi.org/10.1109/PROC.1975.9939>
- [8] David E. Bell, Leonard J. LaPadula. *Secure Computer Systems: Mathematical Foundations*. MITRE Corporation, Technical Report, MTR-2547, 1973.
- [9] John Althouse, Jeff Atkinson, Josh Atkins. *JA3 - A method for profiling SSL/TLS Clients*. Salesforce Engineering, 2017. <https://github.com/salesforce/ja3>
- [10] D. F. Ferraiolo, D. R. Kuhn, R. Chandramouli. *Role-Based Access Control (RBAC): ANSI/INCITS 359-2004 and NIST IR 7316*. National Institute of Standards and Technology. <https://csrc.nist.gov/projects/role-based-access-control>
- [11] John Kindervag. *No More Chewy Centers: Introducing The Zero Trust Model Of Information Security*. Forrester Research, Settembre 2010.
- [12] W3C and FIDO Alliance. *Web Authentication: An API for accessing Public Key Credentials*. W3C Recommendation. <https://www.w3.org/TR/webauthn-2/>
- [13] Martin Roesch. *Snort - Lightweight Intrusion Detection for Networks*. In Proceedings of the 13th USENIX Conference on System Administration (LISA '99), 1999. https://www.usenix.org/legacy/events/lisa99/full_papers/roesch/roesch.pdf